第三章 可信计算技术及应用



提　纲

一　可信计算背景

二　可信计算关键技术分析

三　典型应用案例

四　问题思考及研讨

一、可信计算背景

一、信息安全定义与内涵

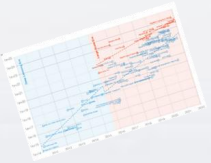
信息系统中，包括两种形态的信息：

（1）静态存储在计算节点上的信息资源，即静态信息

（2）计算节点中运行或在计算节点间传播的信息，即动态信息

从静态观点来看，存储在计算节点上的数据没有被非法读取或修改，即为安全

从动态观点来看，信息处理的实际效果与用户预期的结果一致，即是安全



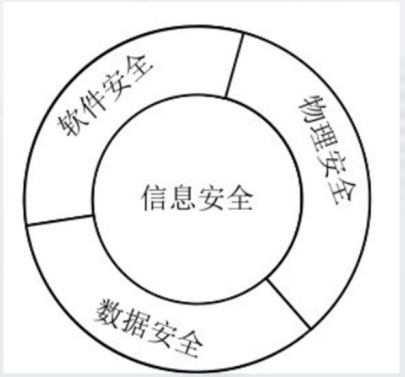


信息安全的内容应包括：

（1）物理安全

（2）软件安全

（3）数据安全





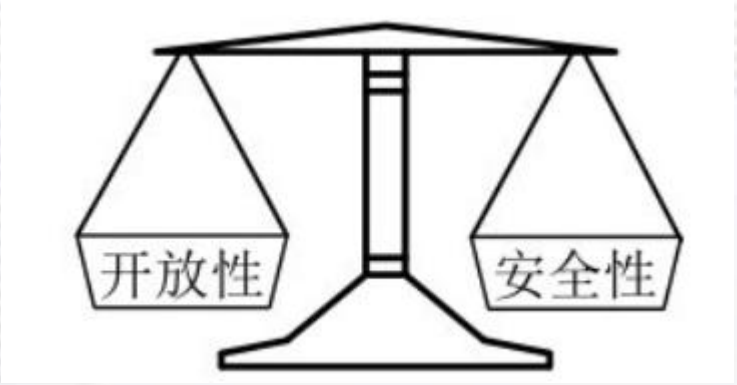
安全性是信息的一个基本属性，涉及信息系统的本质缺陷、内在缺陷、外在缺陷

一、信息系统的本质缺陷

信息的开放性和安全性共存矛盾



人工智能泛化性与系统可信性





大数据共享与数据安全

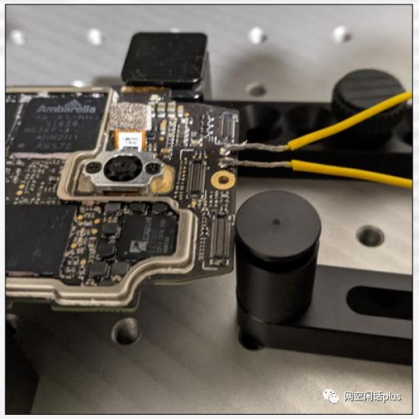


互联网的开放性与安全性

一、信息系统的内在缺陷

信息系统在硬件、软件、协议等基础部件存在设计、实现的安全问题

- 各种计算设备、通信终端和通信介质受到温度、湿度、静电、电磁场、闪电等自然因素及器件的物理老化的影响可能造成物理器件的失效、损坏或信息的泄漏。

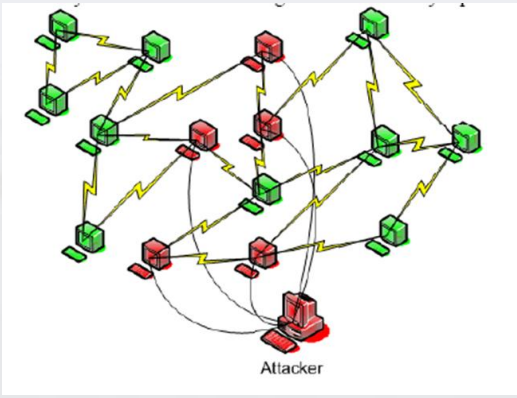


- 在软件设计中的疏忽可能造成软件系统内部逻辑错误或留下安全漏洞。软件工程实现中缺乏规范化和模块化要求，将导致软件的安全等级达不到所声称的安全级别。



图 2-67　Phobos 勒索病毒的勒索信示例（来源：亚信科技（成都）有限公司）

- TCP协议建立一个完整的TCP连接，需要经历3次握手过程，攻击者利用这一过程可以实现如TCP SYN Flooding的DoS拒绝服务攻击



一、信息系统外在缺陷（攻与防的对抗）

访问控制机制（RBAC模型）

基于角色的访问控制：CoreRBAC。

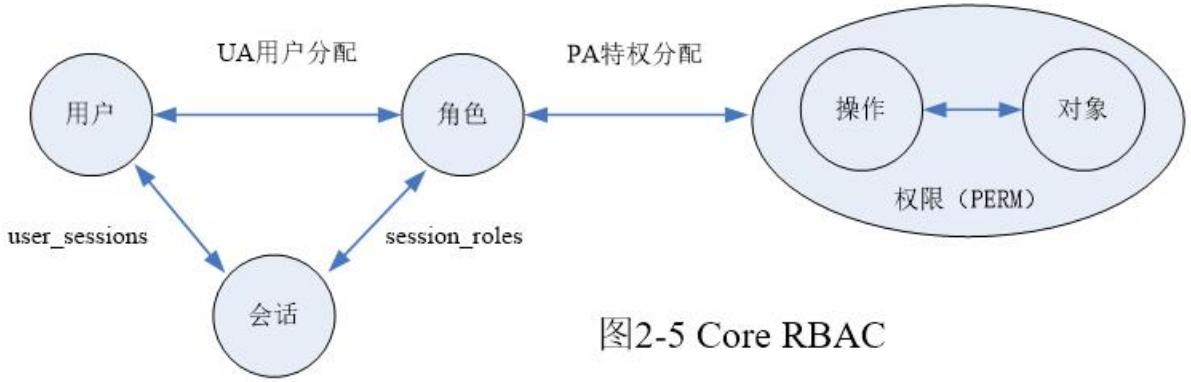
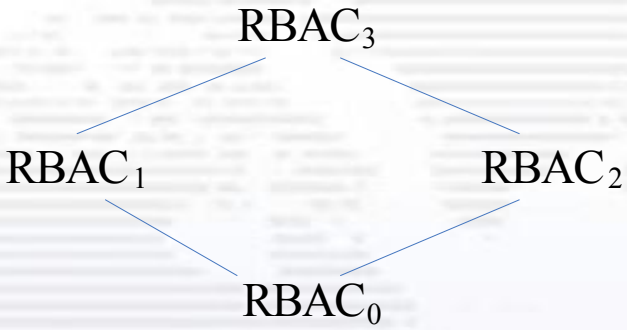
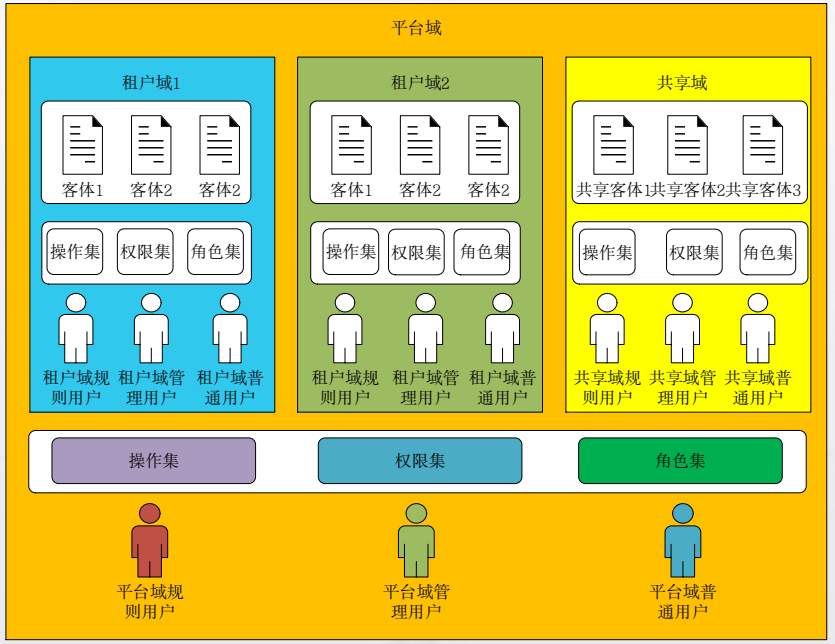


图2-5 Core RBAC

① 用户是访问控制的主体，可以发起访问操作请求。
② 对象是访问控制的客体，指系统中受访问控制机制保护的资源。
③ 操作是指对象上能够被执行的一组访问操作。
④ 权限是指对象及其上指定的一组操作。
⑤ 角色是权限分配的载体，是一组有意义的权限集合。
⑥ 会话用于维护用户和角色之间的动态映射关系。

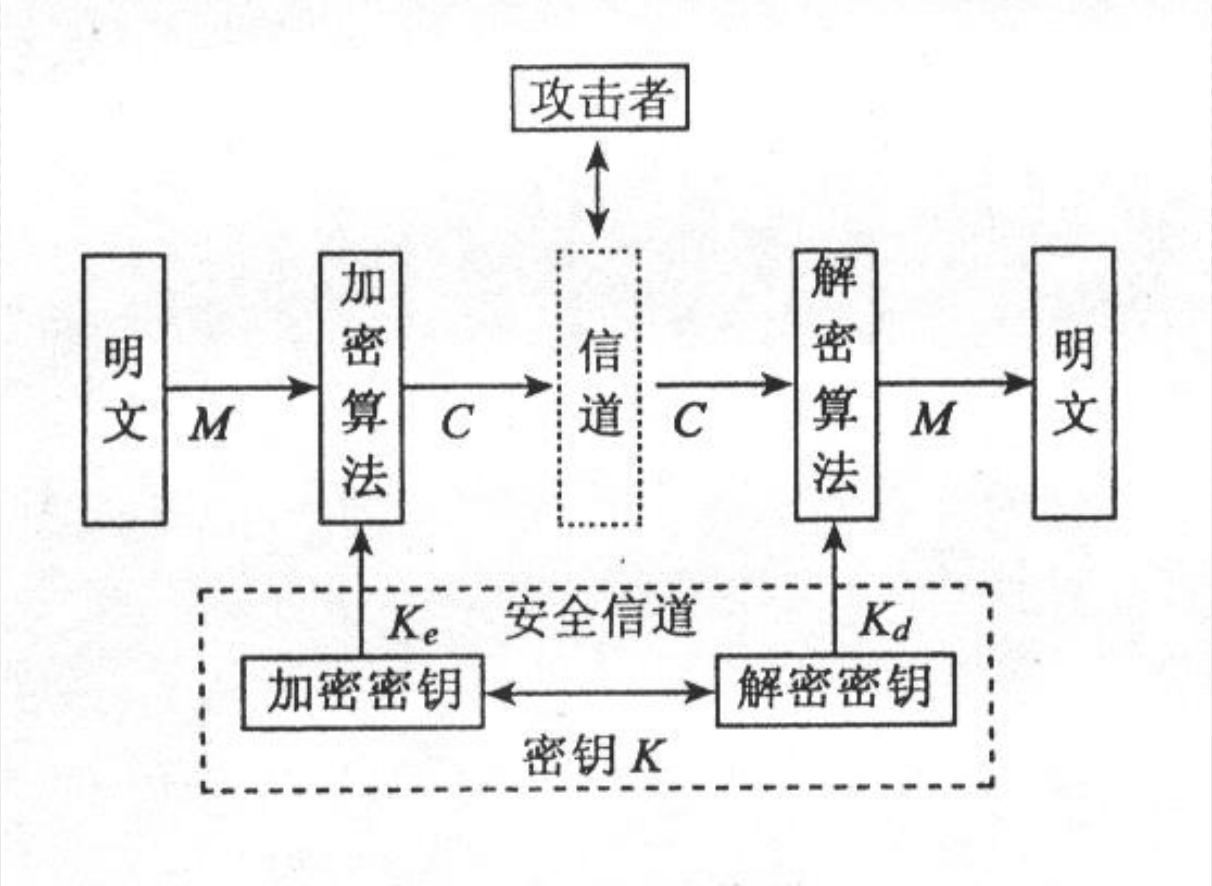




多租户下的RBAC

一、信息系统外在缺陷（攻与防的对抗）

密码体制：由五元组（M,C,K,E,D）构成密码体制模型



一、信息系统外在缺陷（攻与防的对抗）

一个密码系统，通常简称为密码体制（Cryptosystem）

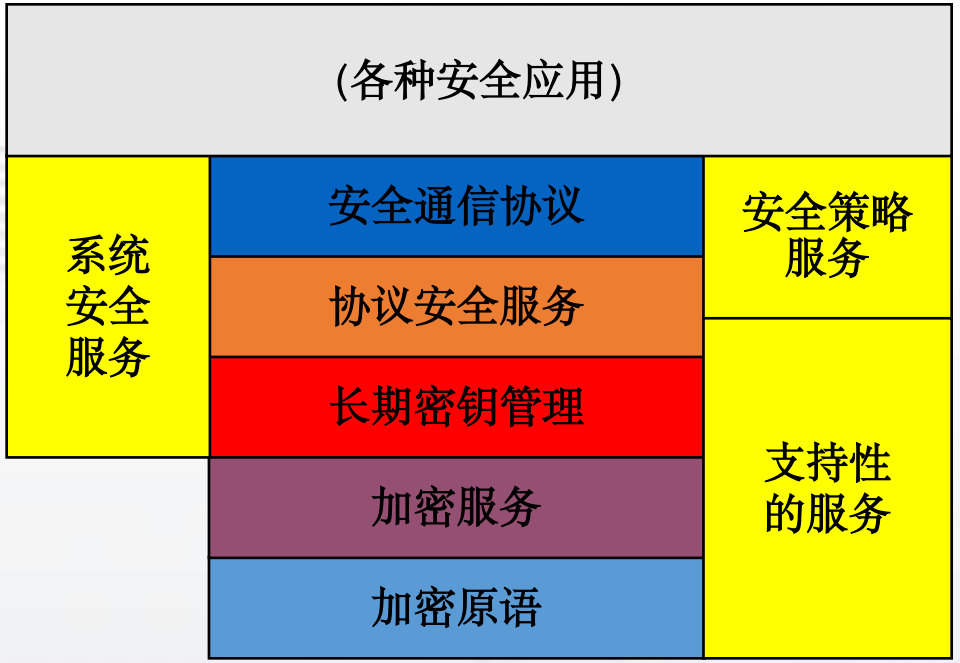
传统密码体制（Conventional Cryptographic System）所用的加密密钥和解密密钥相同，或实质上等同，即从一个密钥易于推出另一个，我们称其为单钥或对称密码体制（One-key or Symmetric Cryptosystem）。

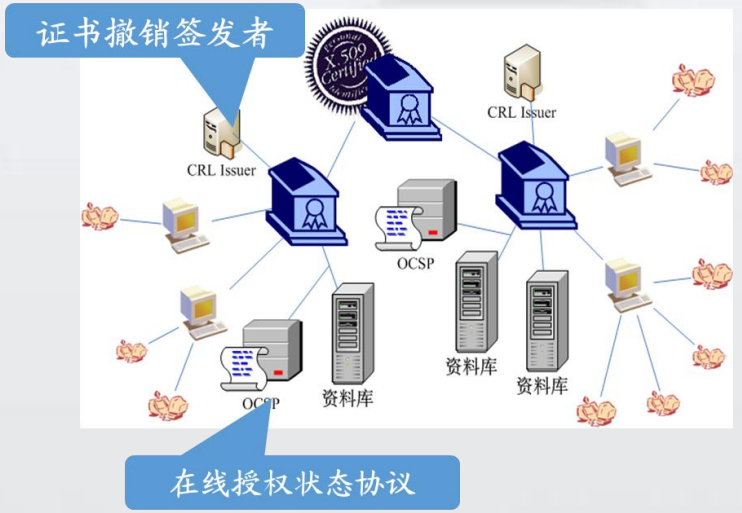
如果加密密钥与解密密钥不相同，即从一个难以推出另一个，则称该密码体制为双钥密码体制（Two-key Cryptosystem）或非对称密码体制（Asymmetric Cryptosystem）。

一、信息系统外在缺陷（攻与防的对抗）

- 对称密码体系
  - 基于替换和置换，“RCC, DES，AES”
- 非对称密码体系
  - RSA, PKI
- 同态密码体系
  - 密文操作等价于明文上的操作
- 密钥协商与管理
  - 关键信息“密钥”的管理与分发

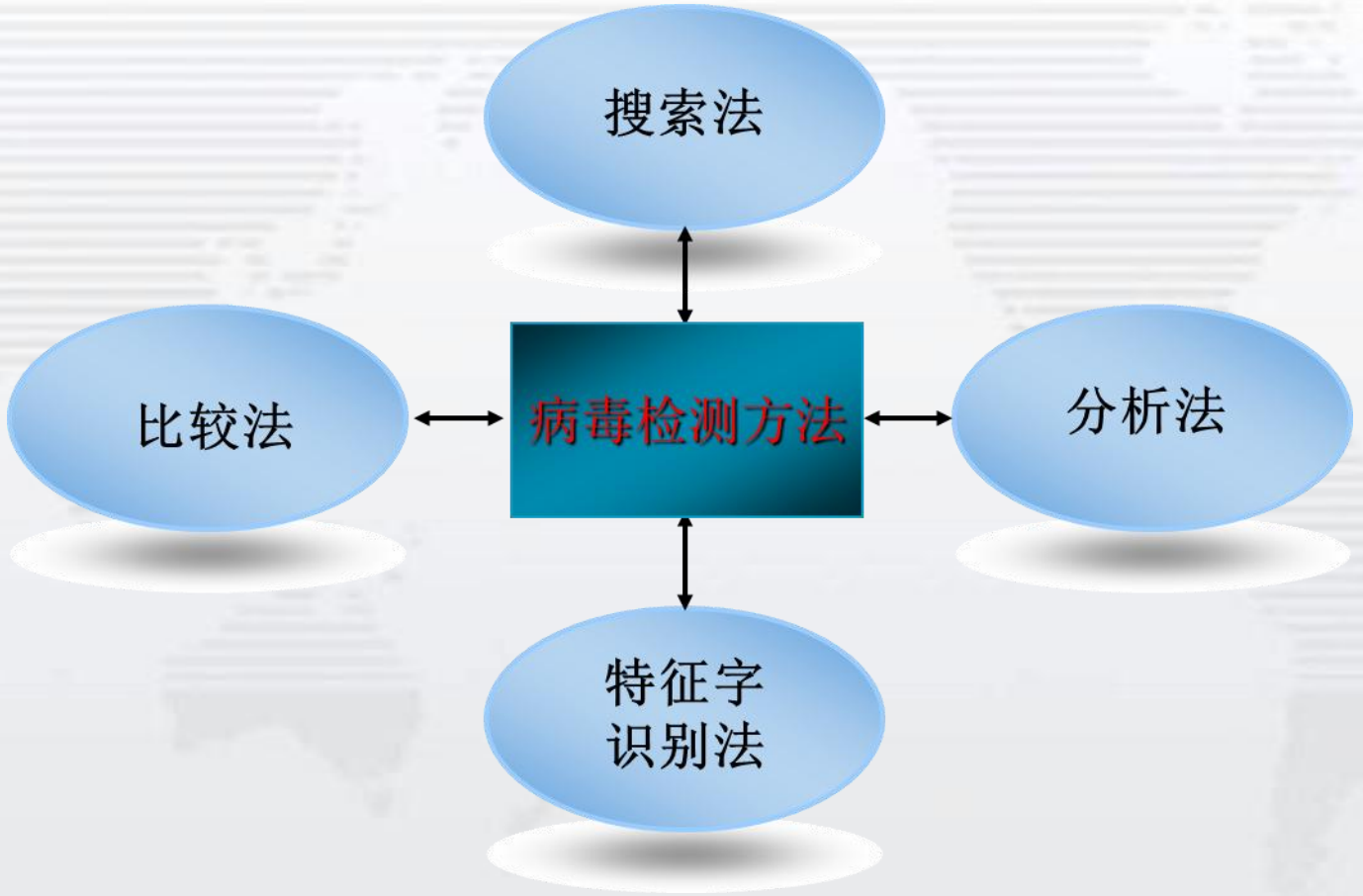
PKI体系架构





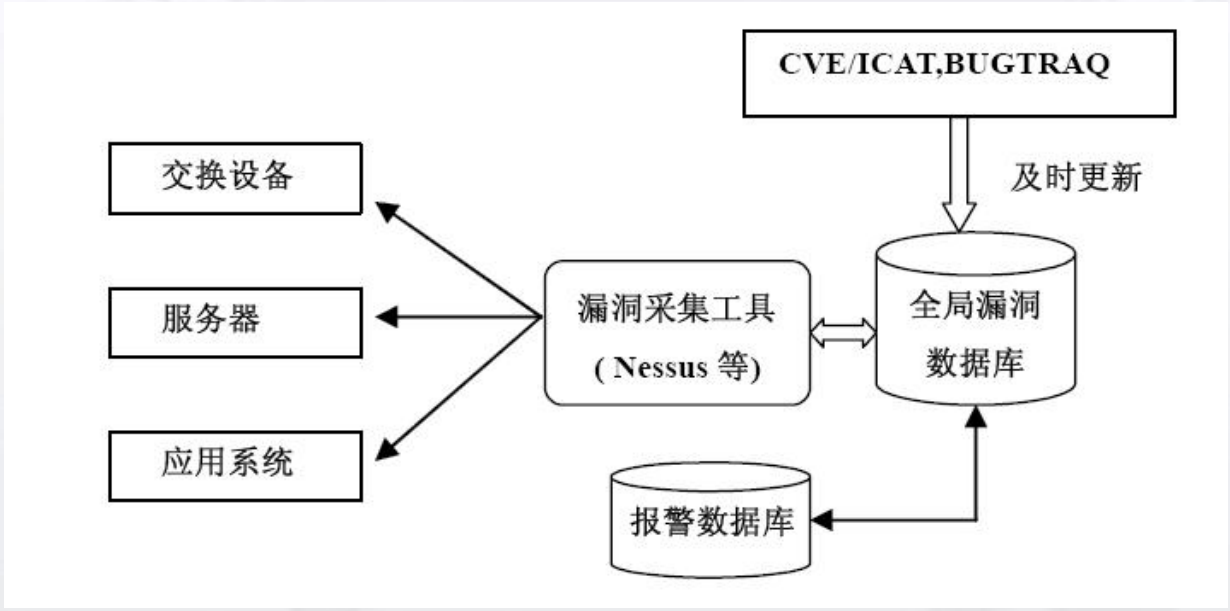
一、信息系统外在缺陷（攻与防的对抗）

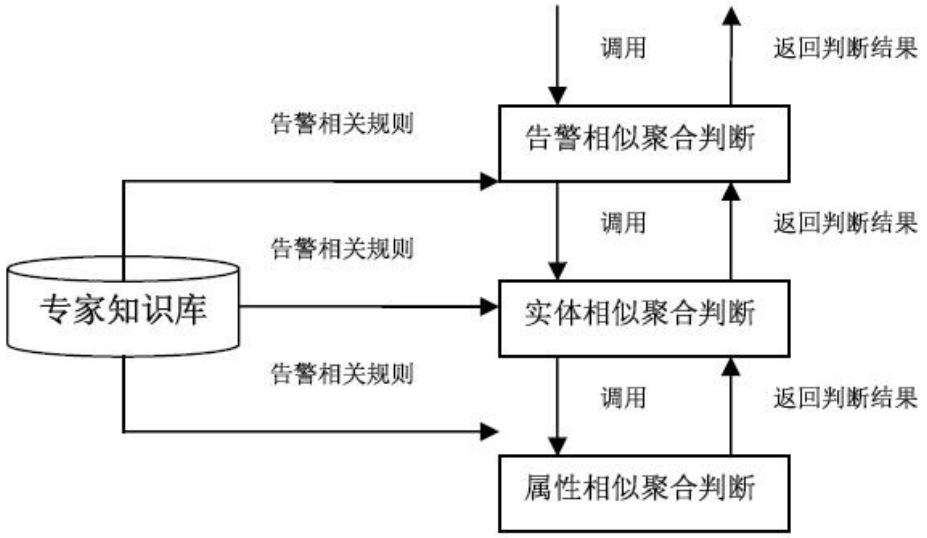
恶意软件、病毒检测



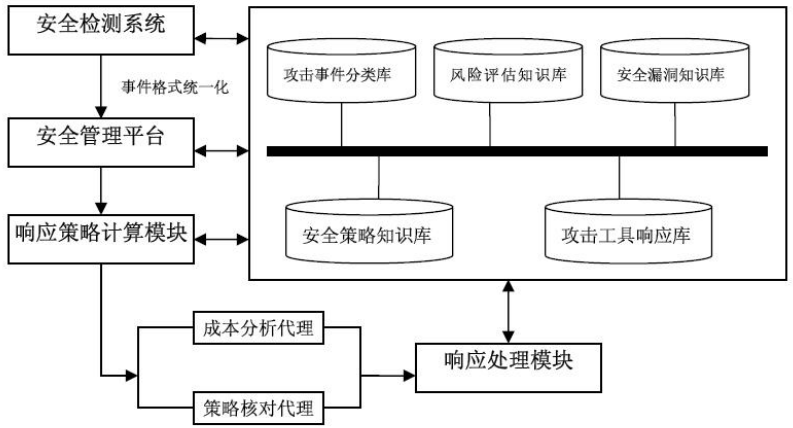
一、信息系统外在缺陷（攻与防的对抗）

入侵检测、异常检测系统





图表三-12：告警事件相似聚合关系的模型



图表五-22：基于代价敏感的主动响应决策模型结构图

一、信息系统外在缺陷（攻与防的对抗）

思考1. 攻击防护手段单一，防火墙、杀毒软件、入侵检测、异常检测老三样

思考2. 访问控制和密码学方法只能抵御非授权用户的非法访问，缺乏系统内保护能力

思考3. 安全可信的信息交互，是信息系统安全的核心目标

一、可信计算的形成与发展

- 1985年美国国防部制定了世界上第一个《可信计算机系统评价准则（Trusted Computer System Evaluation Criteria，TCSEC）》，标志着可信计算的诞生， 可信计算基（TCB）作为系统安全的基础
- 20世纪90年代中期，国外一些计算机厂商就开始提出通过在硬件层嵌入一个安全模块，基于密码技术建立可信根、安全存储和信任链机制，实现可信计算安全目标的可信计算技术方案。该技术思路于1999年逐步被IT产业界接受和认可
- 2001年，可信计算平台联盟（TCPA）提出了可信平台模块（Trusted Platform Module，TPM）1.1技术标准
- 2009年该规范体系的4个核心标准成为ISO国际标准ISO/IEC 11889
- 2015年TPM标准升级为2.0版本，形成了可信计算的新高潮， TPM成为许多笔记本和台式机的标配部件

一、可信计算的形成与发展

国内技术发展可以概括为三个阶段：

第1个阶段消化吸收（2000~2005年）

武汉瑞达公司和武汉大学	第一款自主研制的可信计算平台
解放军密码管理委员会	召开第一届中国可信计算学术会议
联想集团和兆日公司	成功研制第一个TPM芯片和可信计算机产品
全国信息安全标准化技术委员会	成立第一个可信计算标准工作小组

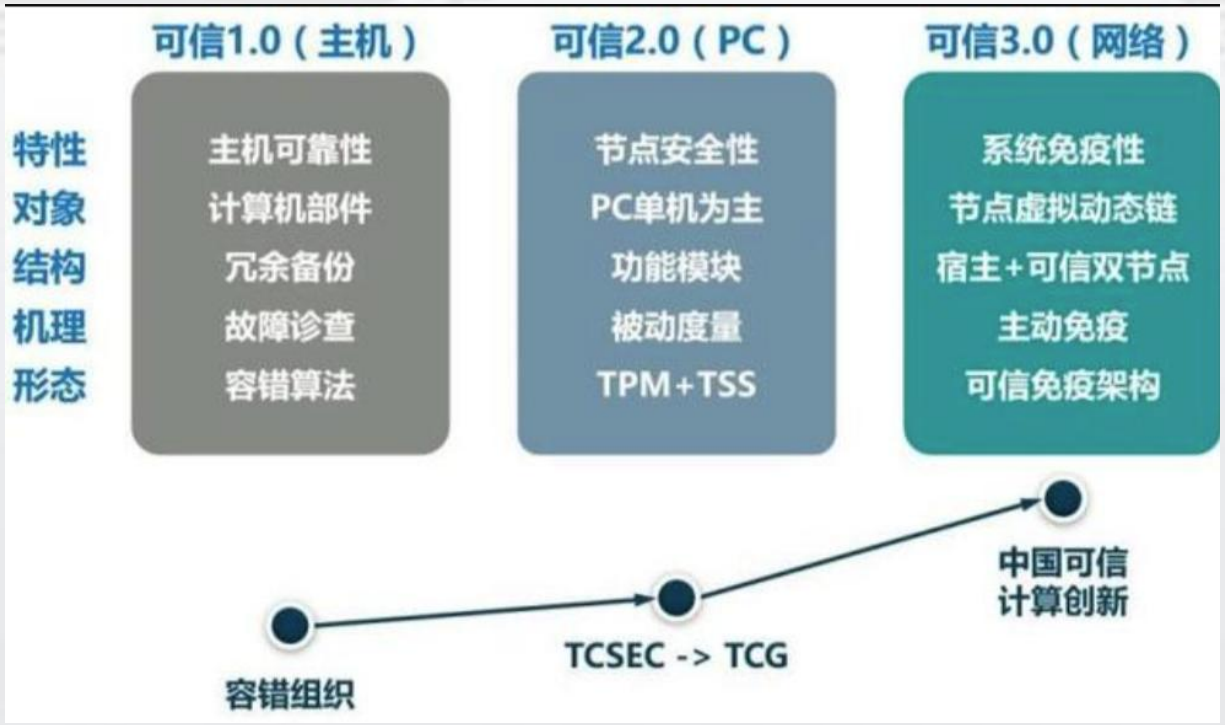
第2个阶段自主创新和标准化（2006~2007年）

联想、国民技术、中国科学院软件所、同方、兆日、瑞达等11家单位联合制定出以可信密码模块（Trusted Cryptography Module，TCM）为核心的《可信计算密码支撑平台技术规范》系列标准，并于2007年12月颁布《可信计算密码支撑平台功能与接口技术规范》

一、可信计算的形成与发展

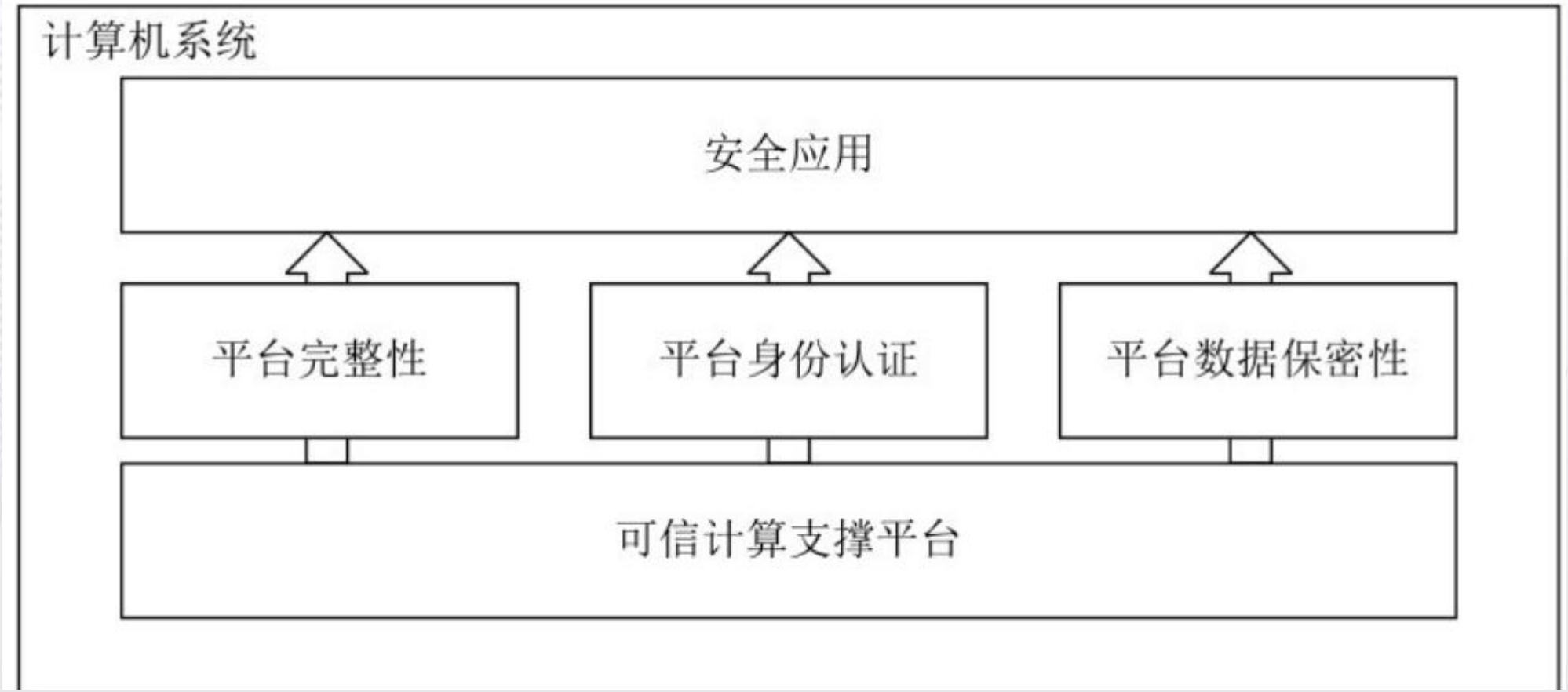
第3个阶段产业化推广（2008年以后）

形成了可信计算安全芯片、可信计算机、可信网络和应用、可信计算产品测评的基本完整的产业体系



一、可信计算的基本概念

可信计算支撑平台在计算机系统中的功能



一、可信计算的基本概念

可信计算平台的定义

可信计算平台（Trusted Computing Platform）是能够提供可信计算安全服务的计算机软硬件综合实体，即对外提供**平台完整性报告**、**平台身份认证**、基于可信硬件模块平台的**数据保密**等安全服务。它的基本目标就是建立一个可信域，并基于该信任域的管理系统将单个的可信计算平台扩张到网络中，形成网络的可信域

可信计算平台的基本思想是：首先构建一个**信任根**，再建立一条**信任链**，从信任根开始到硬件平台，到操作系统，再到应用，一级认证一级，一级信任一级，从而把这种信任扩展到整个计算机系统。

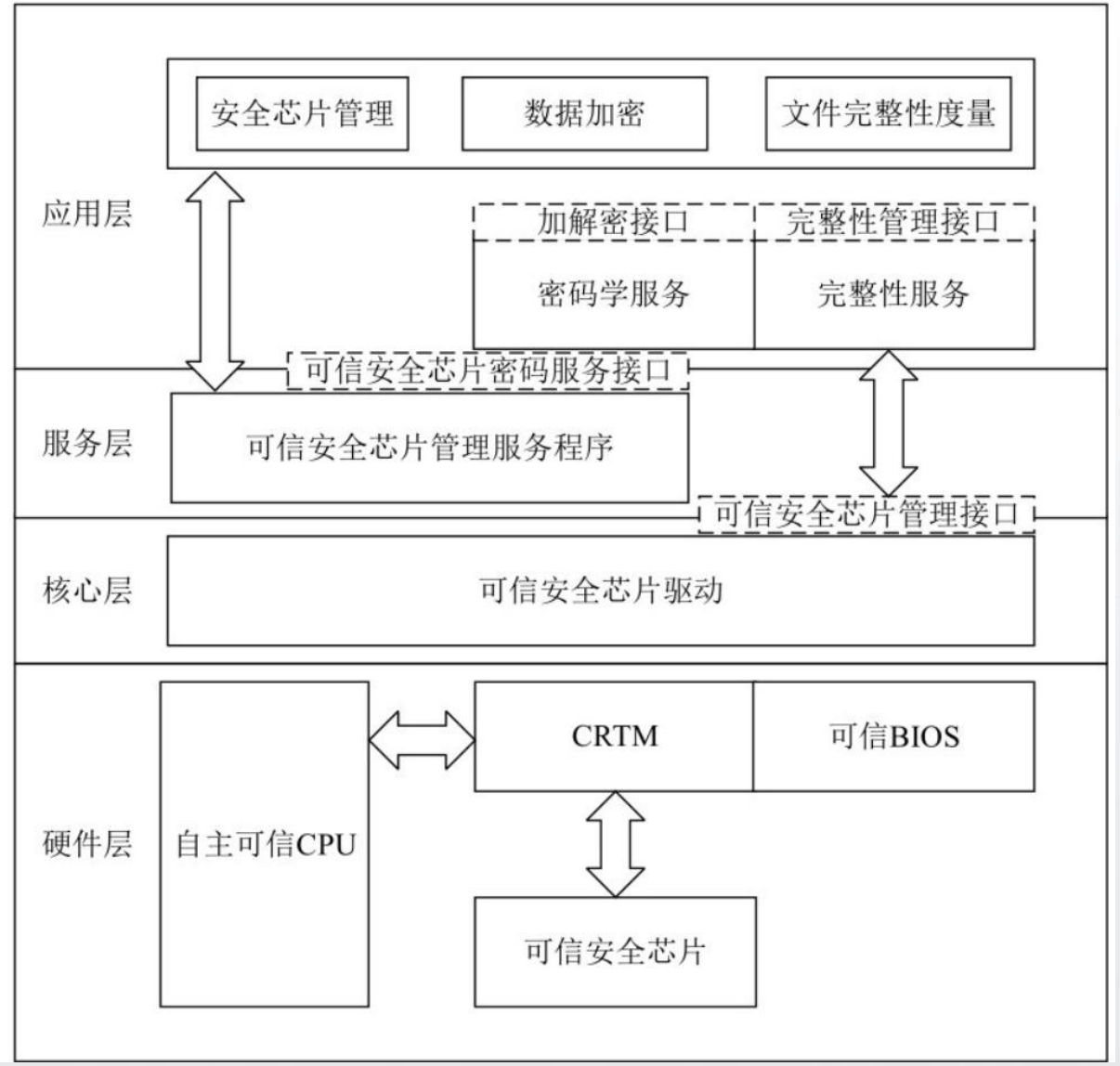
可信计算平台的**3个基本特征**包括：（1）保护能力；（2）证明能力；（3）完整性度量、存储和报告。

一、可信计算的基本概念

可信计算平台是能够提供可信计算服务的**计算机软硬件实体**

它能够提供可信系统的**可靠性**、**可用性**和**行为的安全性**

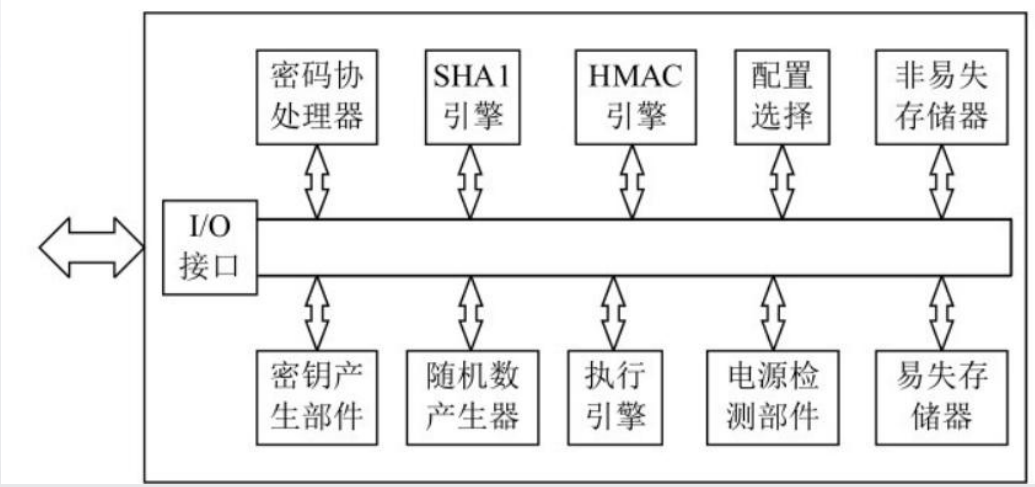
可信计算平台体系结构



一、可信计算的基本概念

可信安全芯片

TPM的逻辑结构，它由**计算引擎**、**存储器**、**I/O**、**密码运算处理器**、**随机数产生器和嵌入式操作系统**等部件组成，完成可信度量的存储、可信度量的报告、系统监控、密钥产生、加密签名、数据的安全存储等功能



TPM的体系结构

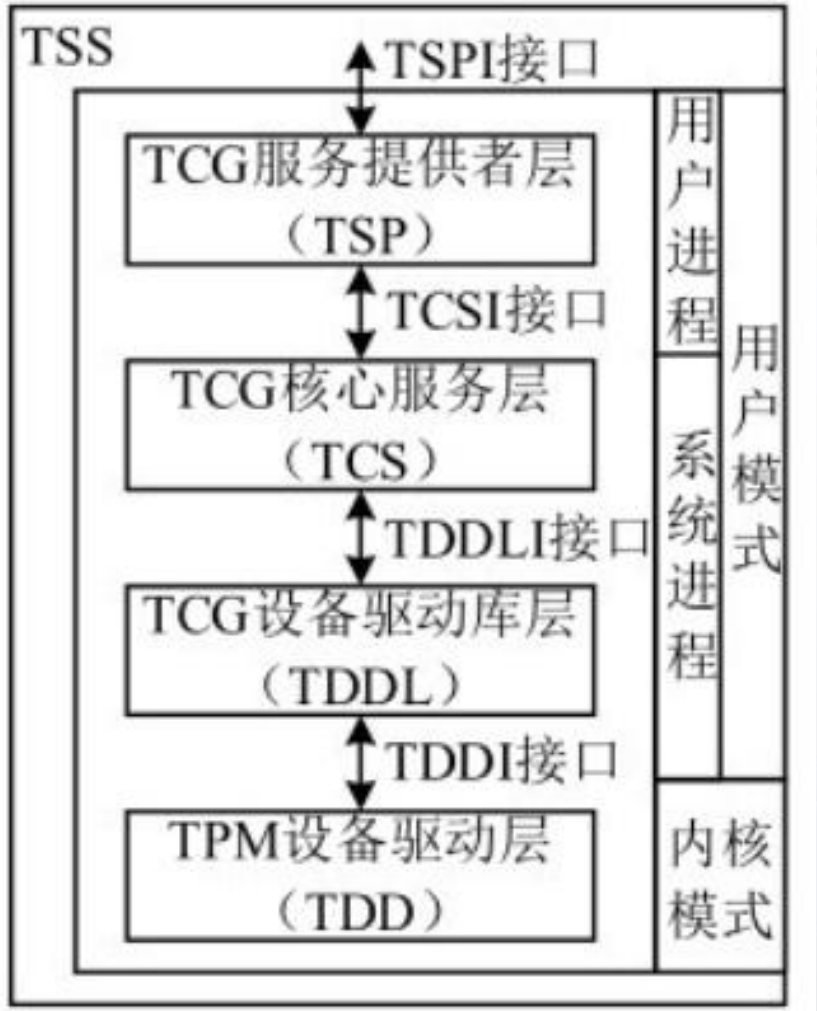
组件	说明
I/O 组件	I/O 组件主要用来对通信总线协议进行编码和译码，是外部实例与 TPM 通信的唯一部件，用来实现外部与 TPM 的信息交换。实际上 TCG 规范中并没有定义专门的 I/O 总线类型，市面上主流 TPM 芯片广泛采用的是 LPC 总线。然而，大多数嵌入式设备并不支持 LPC 总线接口，这就需要我们自己使用通用外部总线，如 SPI、I^2C 或 UART 等进行 TPM 接口扩展
密码协处理器	用来实现加密、解密和签名等硬件加速，TPM 规范中推荐使用非对称的 RSA 算法，但也并没有禁止对称密码算法的使用
密钥产生部件	此模块主要用来产生 RSA 密钥对和对称加密密钥等
HMAC 引擎	用来实现基于 SHA1 的哈希函数消息认证码，其计算根据 RFC 2104 规范
随机数生成器	TPM 内置的随机源，TPM 用它来进行密钥生成以及数字签名等过程中所需的随机数
SHA1 引擎	哈希函数 SHA1 的执行引擎，其输出是 160 比特
电源检测部件	管理 TPM 的电源状态
配置选择	TPM 可以通过控制平台引脚和相应的命令，从物理上控制 TPM 工作状态的模式
执行引擎	包含了 CPU 和 TPM 的程序代码，用来执行并完成用户请求的 TPM 命令，并返回结果
非易失性存储器	用来存储 TPM 永久性身份和相关状态，以及密钥、证书和标识等重要数据
易失性存储器	主要是 TPM 内部工作的存储器

一、可信计算的基本概念

可信支撑软件栈 TSS

软件协议栈是与TPM相配套的可信支撑软件。包括：

TCG设备驱动库层（TCG Device DriverLibrary，TDDL）、**TSS核心服务层**（TCG Core Services，TCS）、**TCG服务提供者层**（TCG Service Provider， TSP）

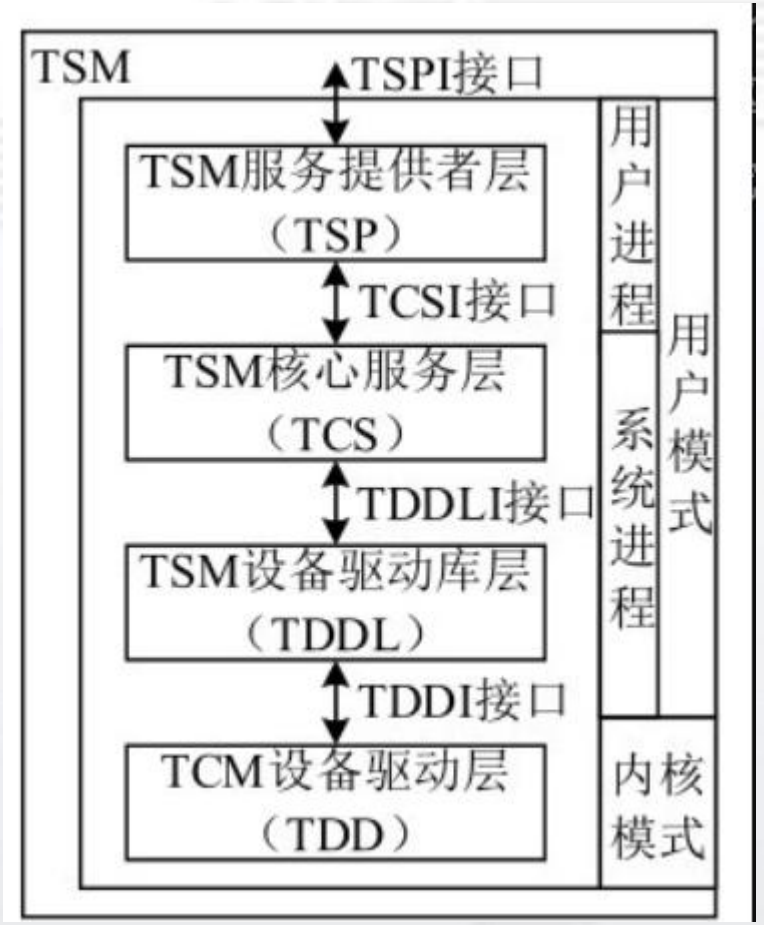


TSS的体系结构

一、可信计算的基本概念

可信服务模块 TSM

TSM由多个软件协议层组成，即**TCM服务提供者层**（TCM Service Provider，TSP）、**TCM核心服务**（TCM Core Service，TCS）和**TCM设备驱动库**（TCM Device Driver Library，TDDL）。



TSM的体系结构

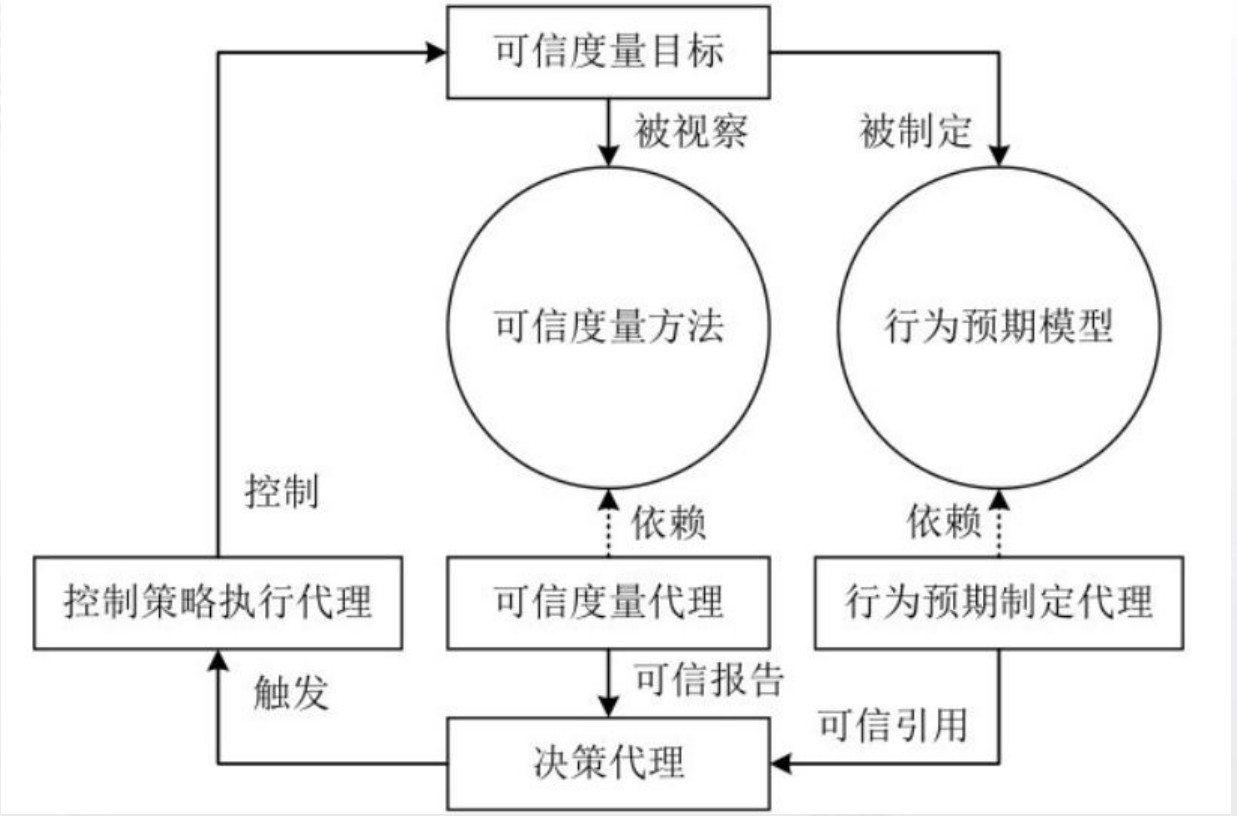
二、可信计算关键技术

二、可信计算关键技术

可信度量

可信度量是可信计算首先要解决的问题。通过对可信的定量描述，能对可信产生更加准确的认识。

度量是指根据预定的规则，采用可行的多种技术手段对某实体对象相关属性进行**测试、收集、分析**和**计算**的持续性定量化和与标准值匹配的过程。

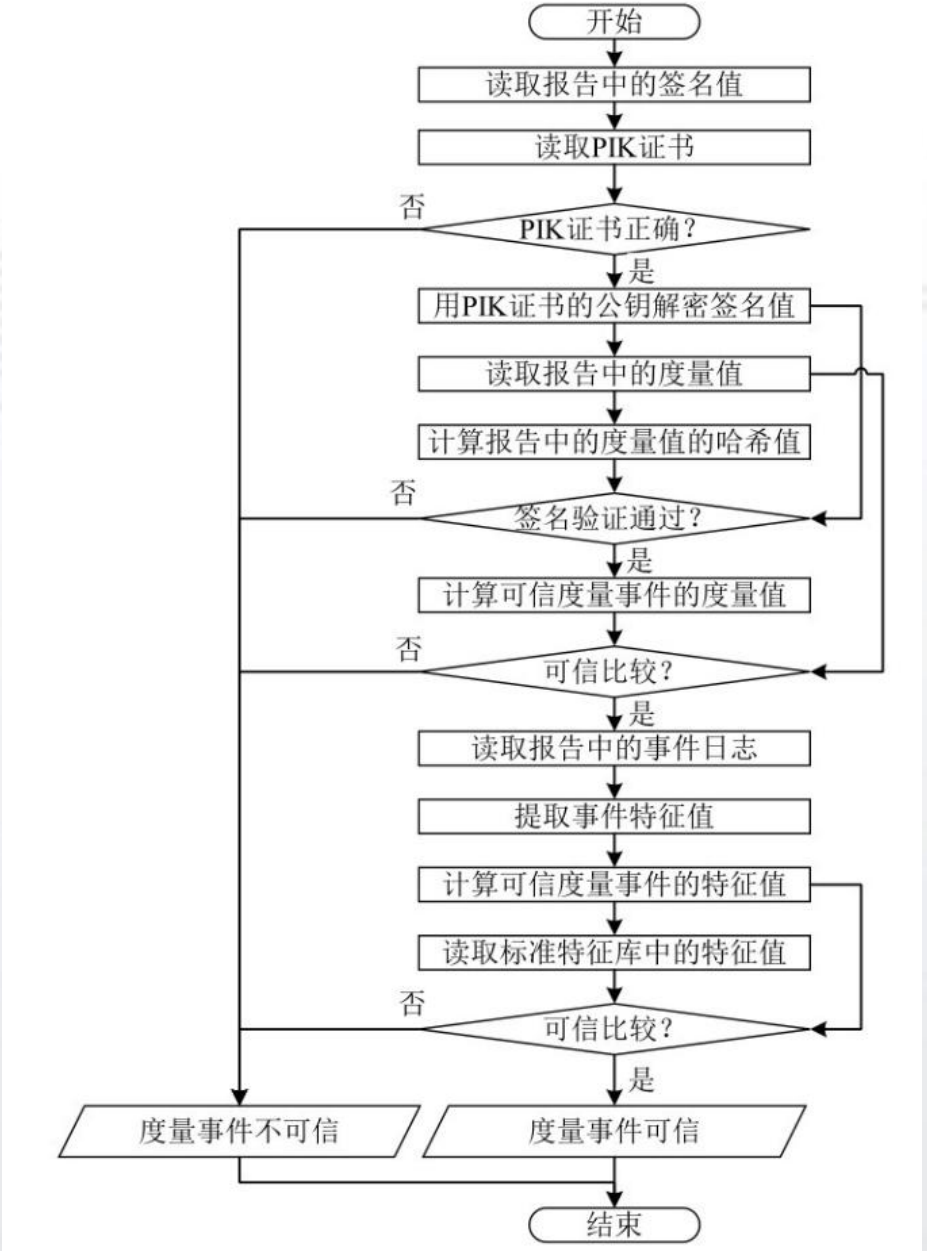


可信度量模型

二、可信计算关键技术

可信度量之完整性度量

验证签名之后，首先从签名中提取出哈希值。根据事件日志计算出一个摘要，得到另外一个哈希值。比较两个哈希值，如果值一样则表示事件日志在传输过程中没有被篡改，并且计算平台是按照事件日志的记录顺序来更新。然后，根据事件日志提取出度量对象特征值，与标准特征库相比较。因为事件日志中的度量对象特征值已经预先存储到标准特征库中，如果事件被修改过，则比对的结果不匹配

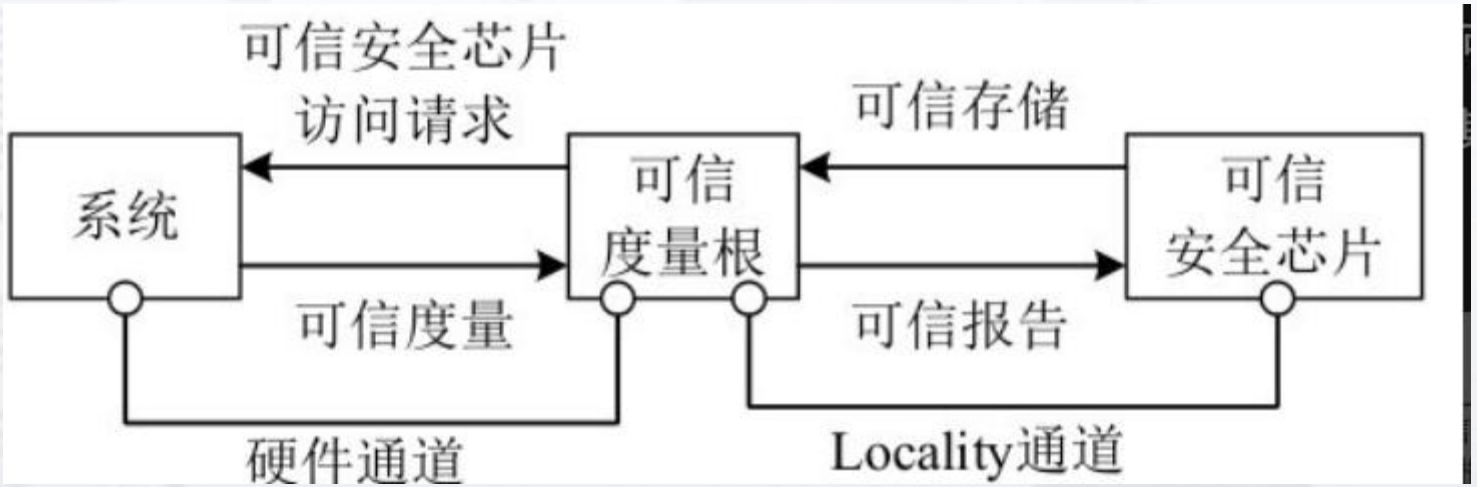


完整性度量计算流程

二、可信计算关键技术

信任链技术

信任链是从信息安全领域借鉴而来的一种机制，是可信计算的核心。它通过引入**硬件上的安全芯片**，从最原始的物理安全角度，建立一个信任根，再建立一条信任链。信任传递的基础是**证明**。当一个组件能够证明另一个组件是值得信赖的，那么信任关系就从一个组件传递到另一个组件



信任链构建模型

二、可信计算关键技术

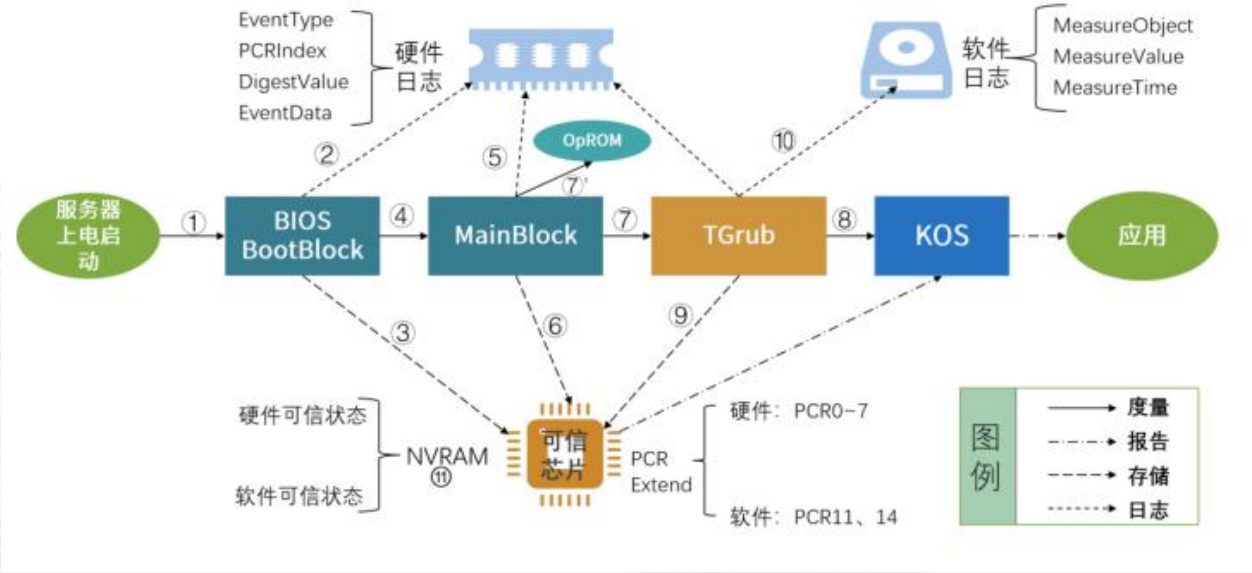
基于无干扰理论的信任链传递模型

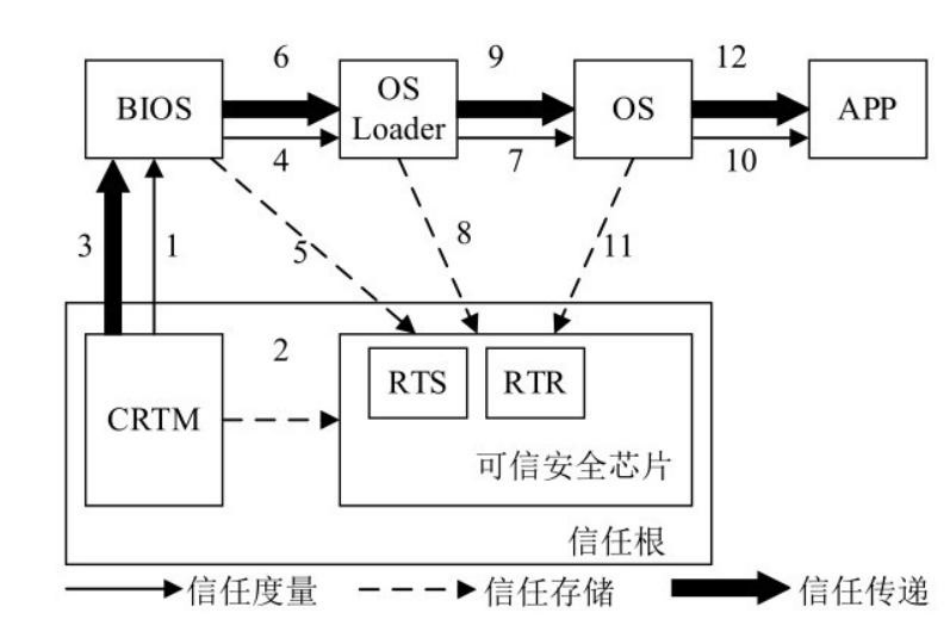
无干扰理论模型是指：如果一个安全域u发出的动作不影响安全域v的输出，则域u对域v是无干扰的。

RTM：可信度量根

RTS：可信存储根

RTR：可信报告根





信任链举例

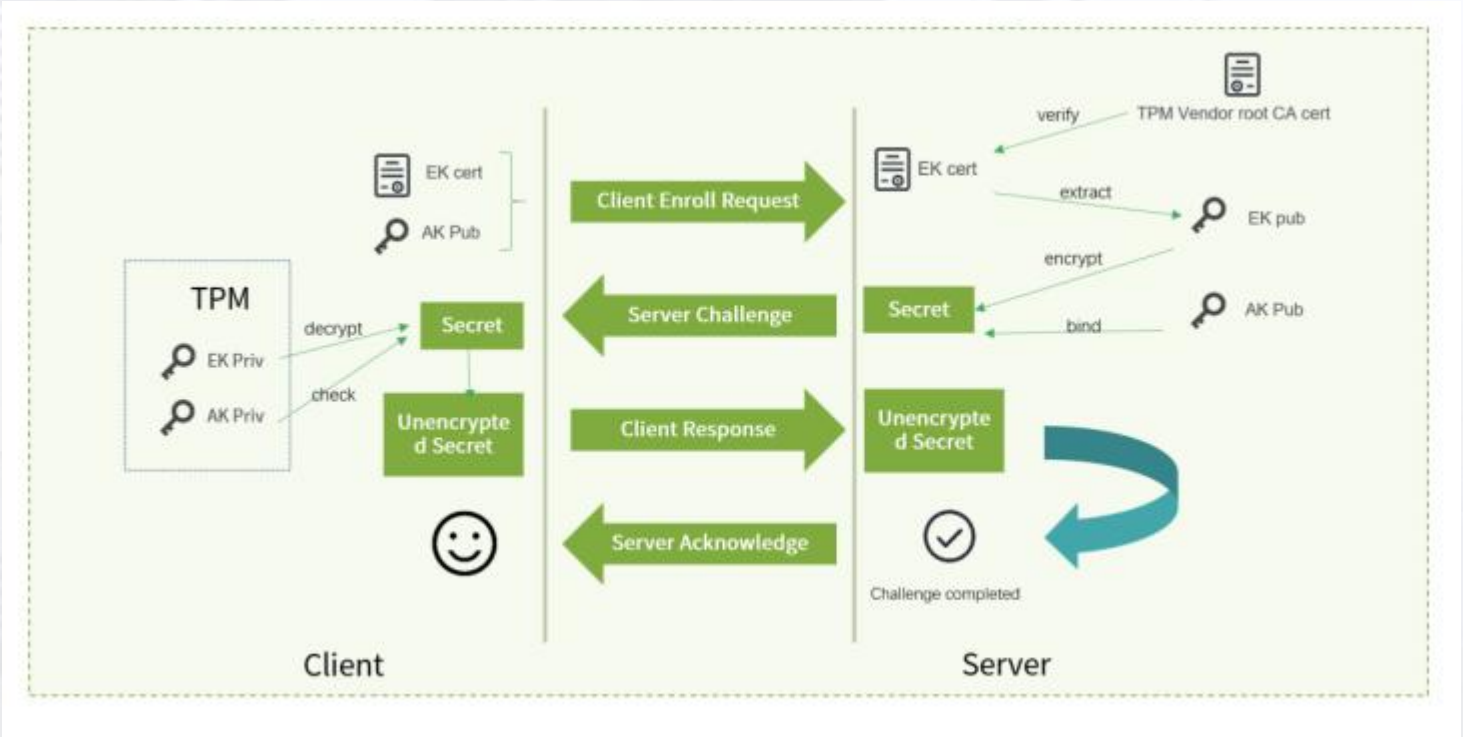
二、可信计算关键技术

远程证明

远程证明包括两个步骤：

（1）服务器验证客户端可信设备

（2）服务器验证来自客户端的度量事件日志



远程证明 设备验证

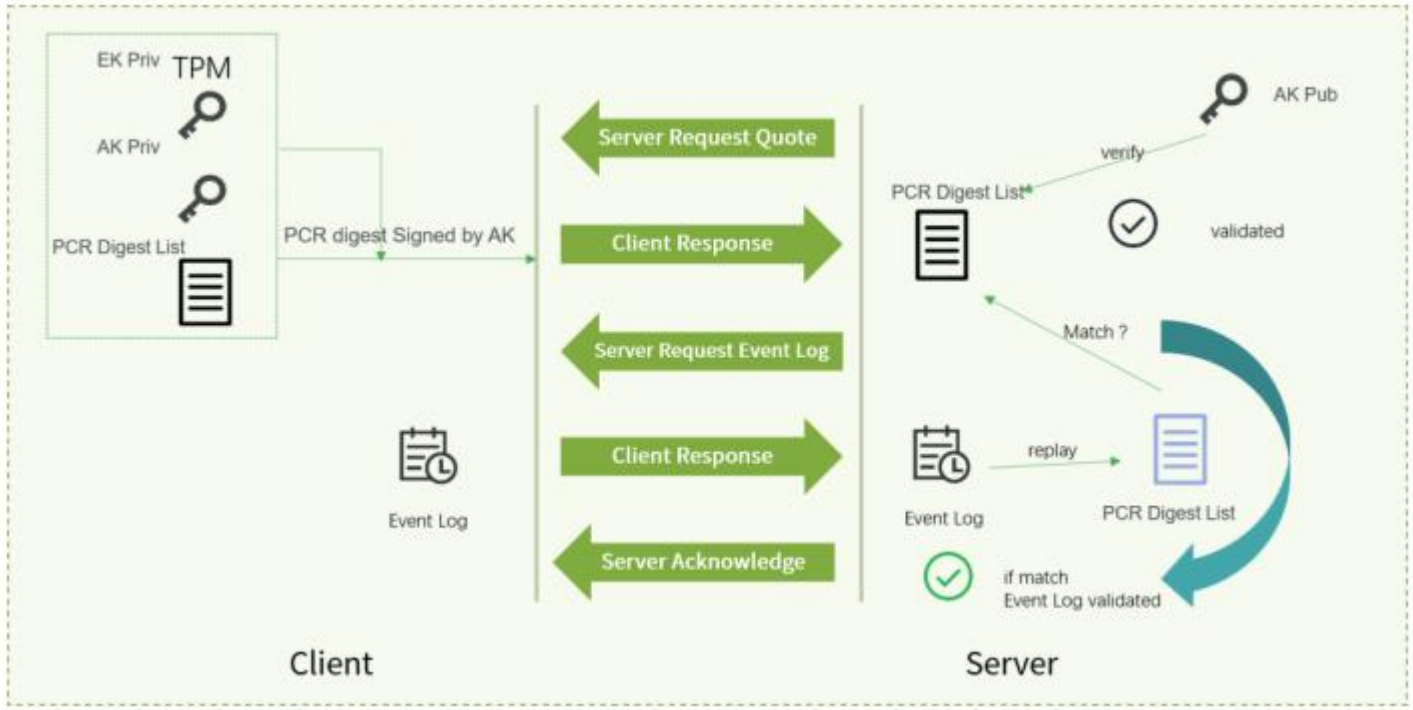
二、可信计算关键技术

远程证明

远程证明包括两个步骤：

（1）服务器验证客户端可信设备

（2）服务器验证来自客户端的度量事件日志



远程证明 日志验证

二、可信计算关键技术

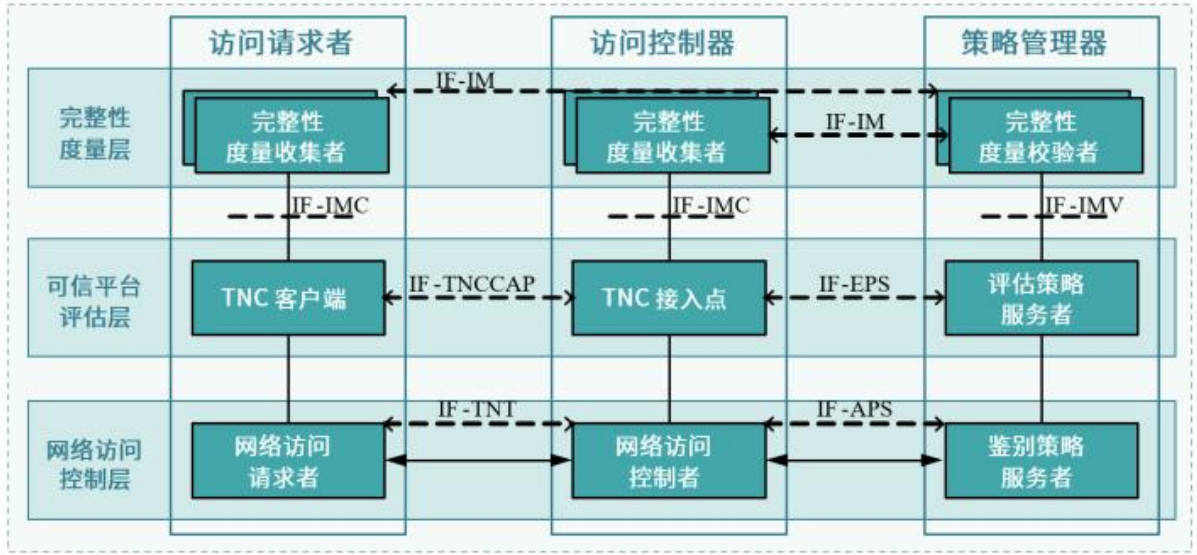
可信网络连接（TNC）

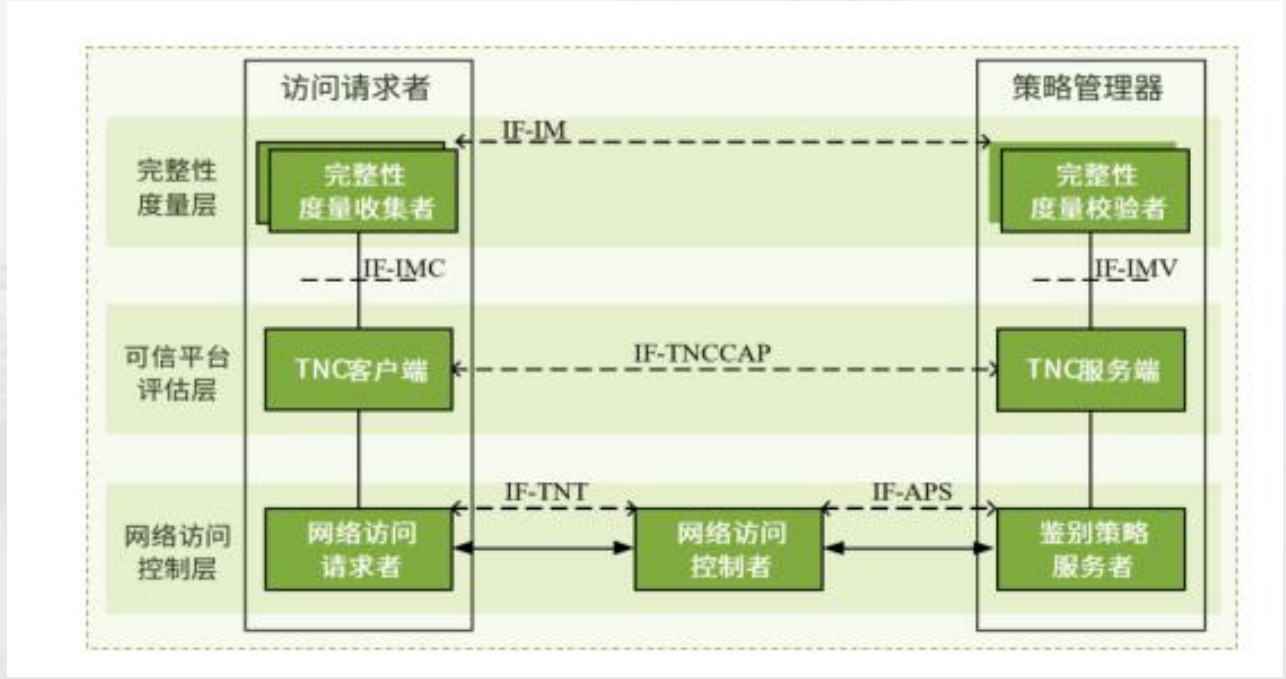
TNC分为三层：

（1）网络访问层：从属于传统网络互联和安全层

（2）完整性评估层：依据安全策略评估访问请求者的完整性状态

（3）完整性度两层：搜集和验证访问请求者的完整性信息





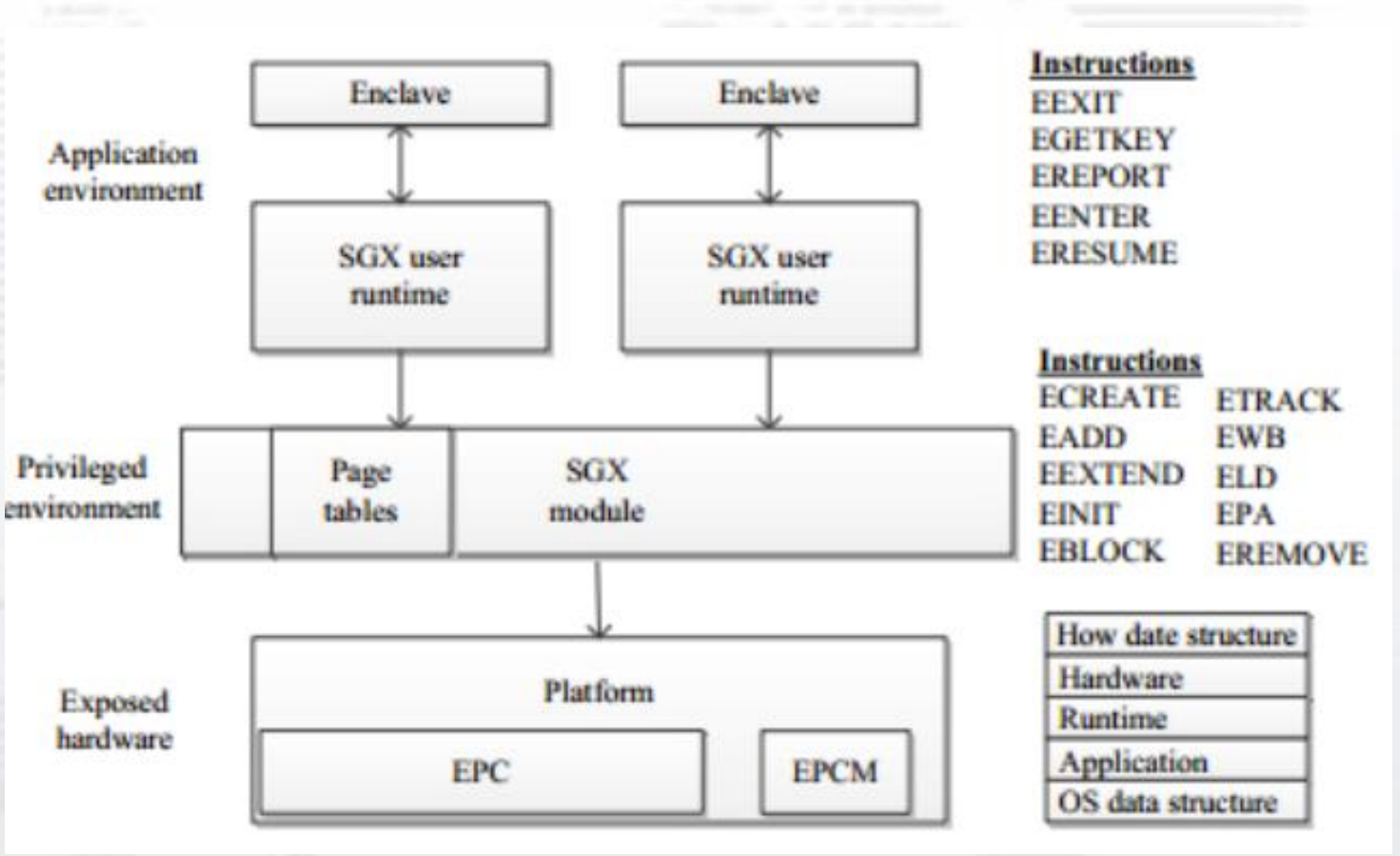
TNC架构

二、可信计算关键技术

Intel SGX

Intel推出SGX(software guard extensions)指令集扩展, 旨在以硬件安全为强制性保障, 不依赖于固件和软件的安全状态, 提供用户空间的可信执行环境

SGX的实现需要处理器、内存管理部件、BIOS、驱动程序、运行时环境等软硬件协同完成



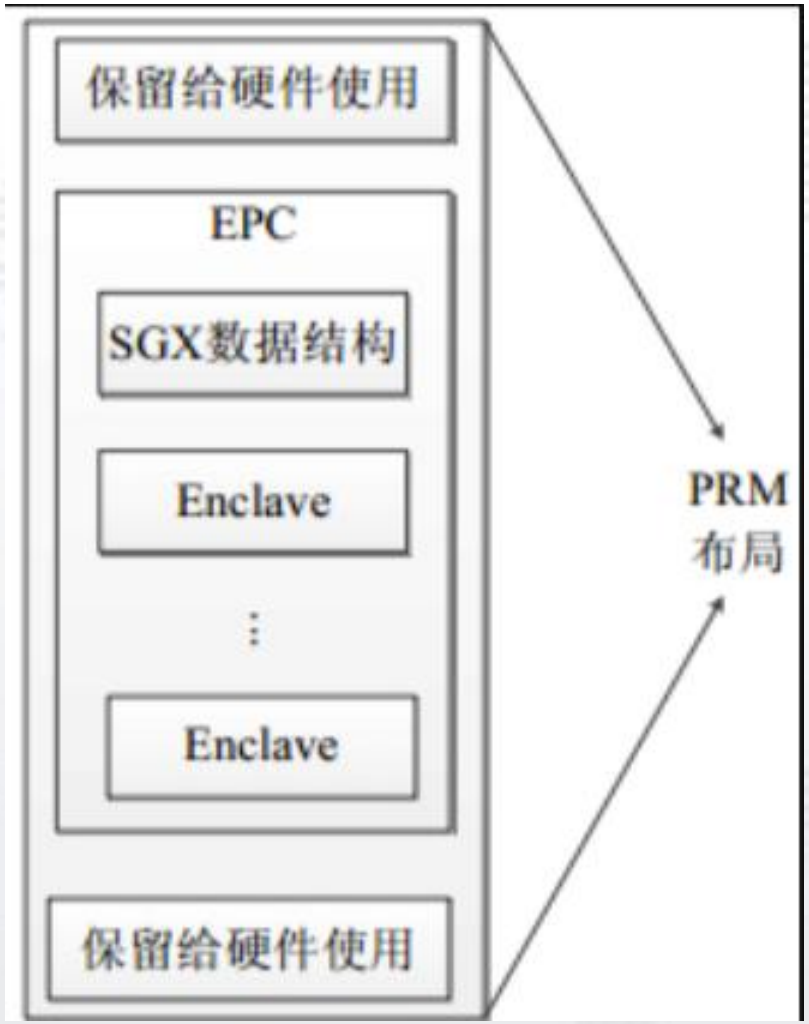
Intel SGX整体架构

二、可信计算关键技术

Intel SGX Enclave安全容器

Enclave是一个被保护的内容容器, 用于存放应用程序敏感数据和代码

所有的enclave都驻留在EPC(enclave page cache)中, 这是系统内一块被保护的物理内存区域, 用来存放enclave和SGX数据结构



处理器保留内存（PRM）示例

二、可信计算关键技术

Intel SGX Enclave安全容器

Enclave具有如下特征：

(1) 具有自己的代码和数据;

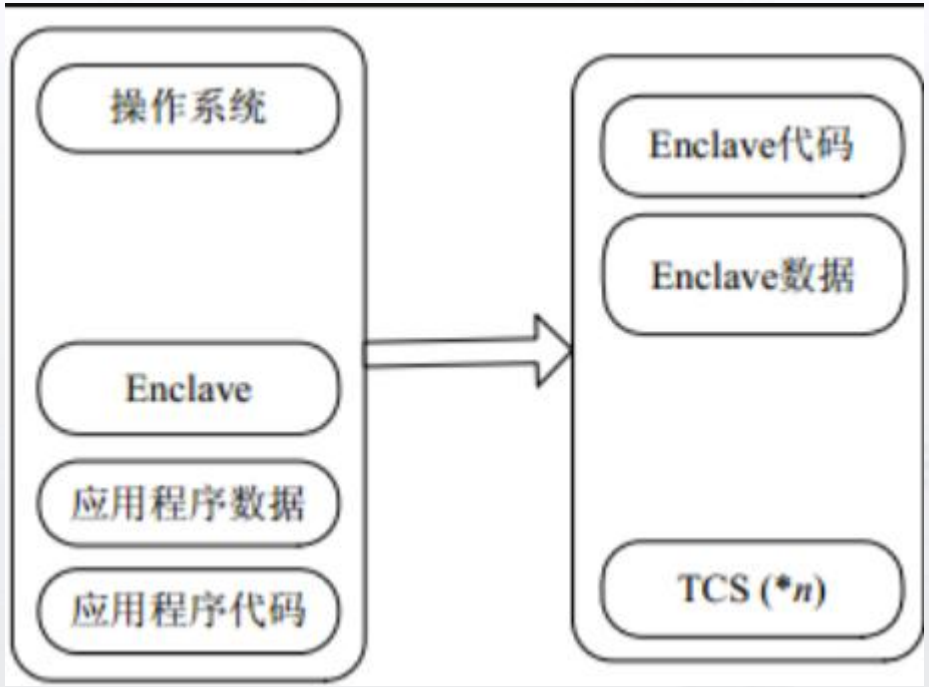
(2) 提供机密性保护;

(3) 提供完整性保护;

(4) 具有可控的入口点;

(5) 支持多线程;

(6) 对应用程序内存具有最高访问权限.



Enclave的结构示意

二、可信计算关键技术

Intel SGX Enclave内存访问语义

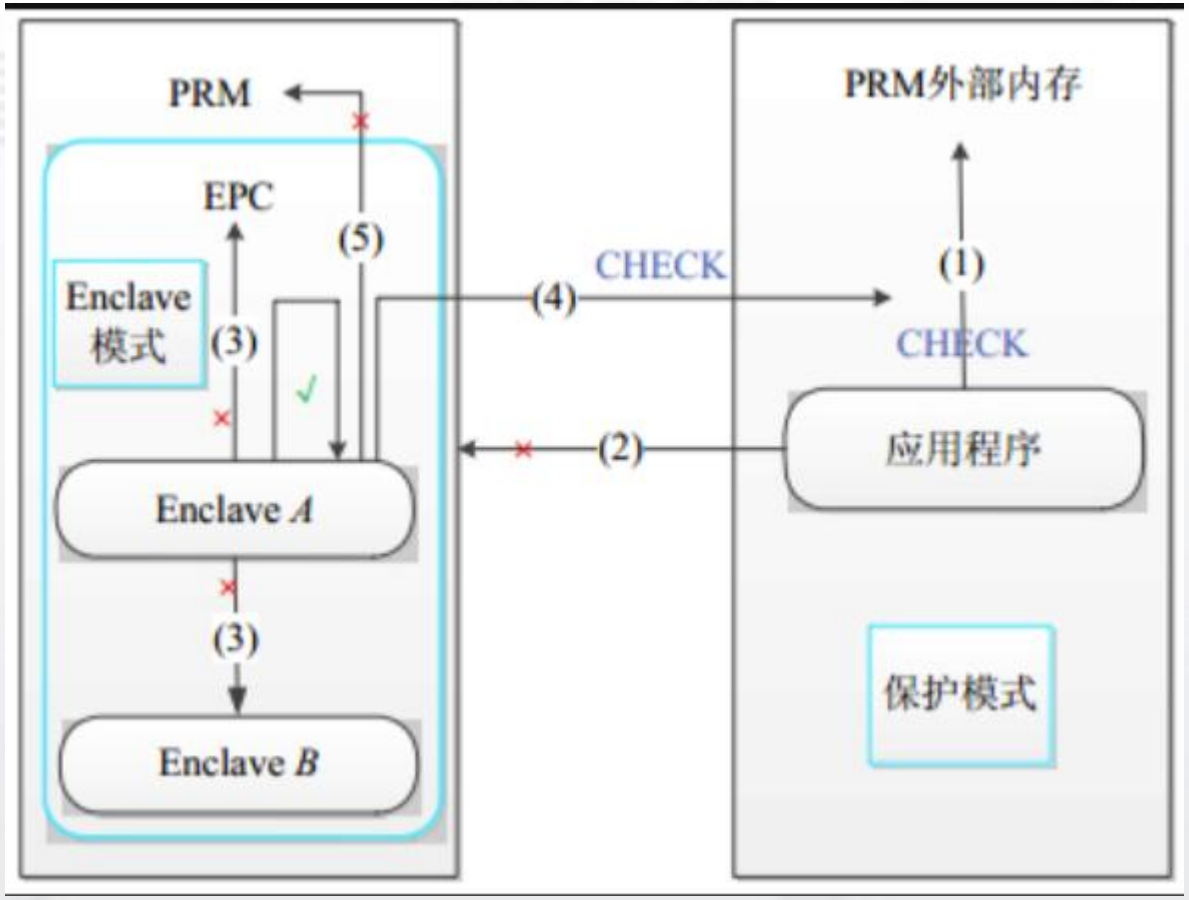
访问enclave内存，硬件将执行下列的检查：

(1) 处理器当前运行在enclave mode中;

(2) 访问地址在enclave地址空间;

(3) 物理地址在EPC内存中;

(4) EPCM(enclave page cache map)检查, 请求访问的页属于正在运行的enclave(只有enclave内的代码才能访问该enclave的内容).

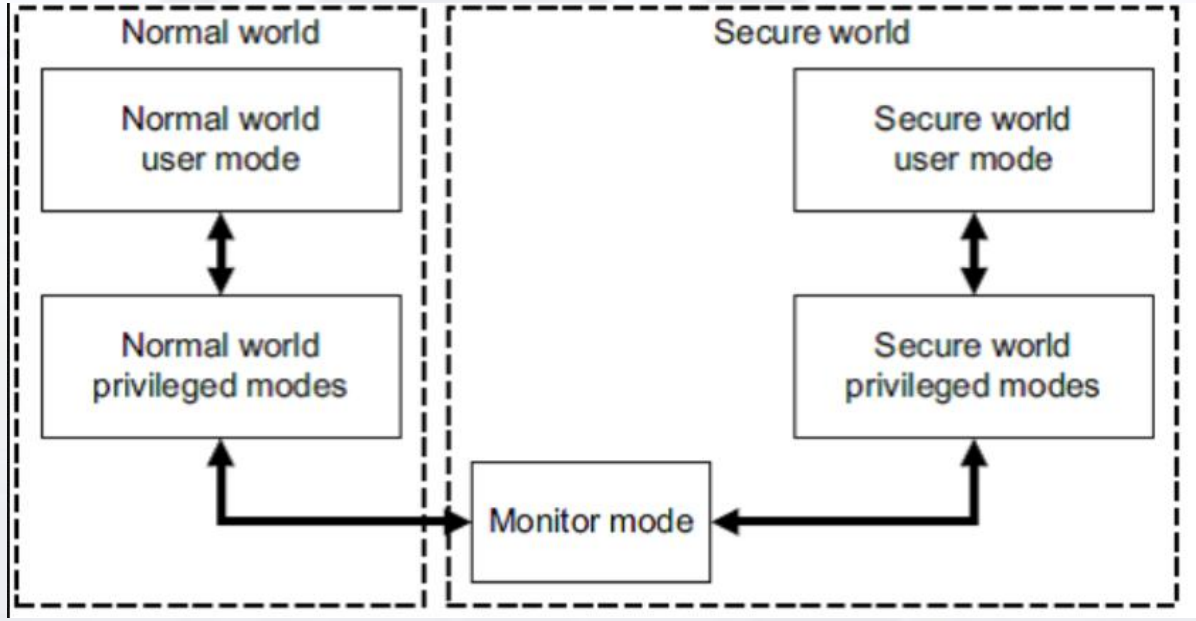


SGX内存访问控制

二、可信计算关键技术

ARM TrustZone技术

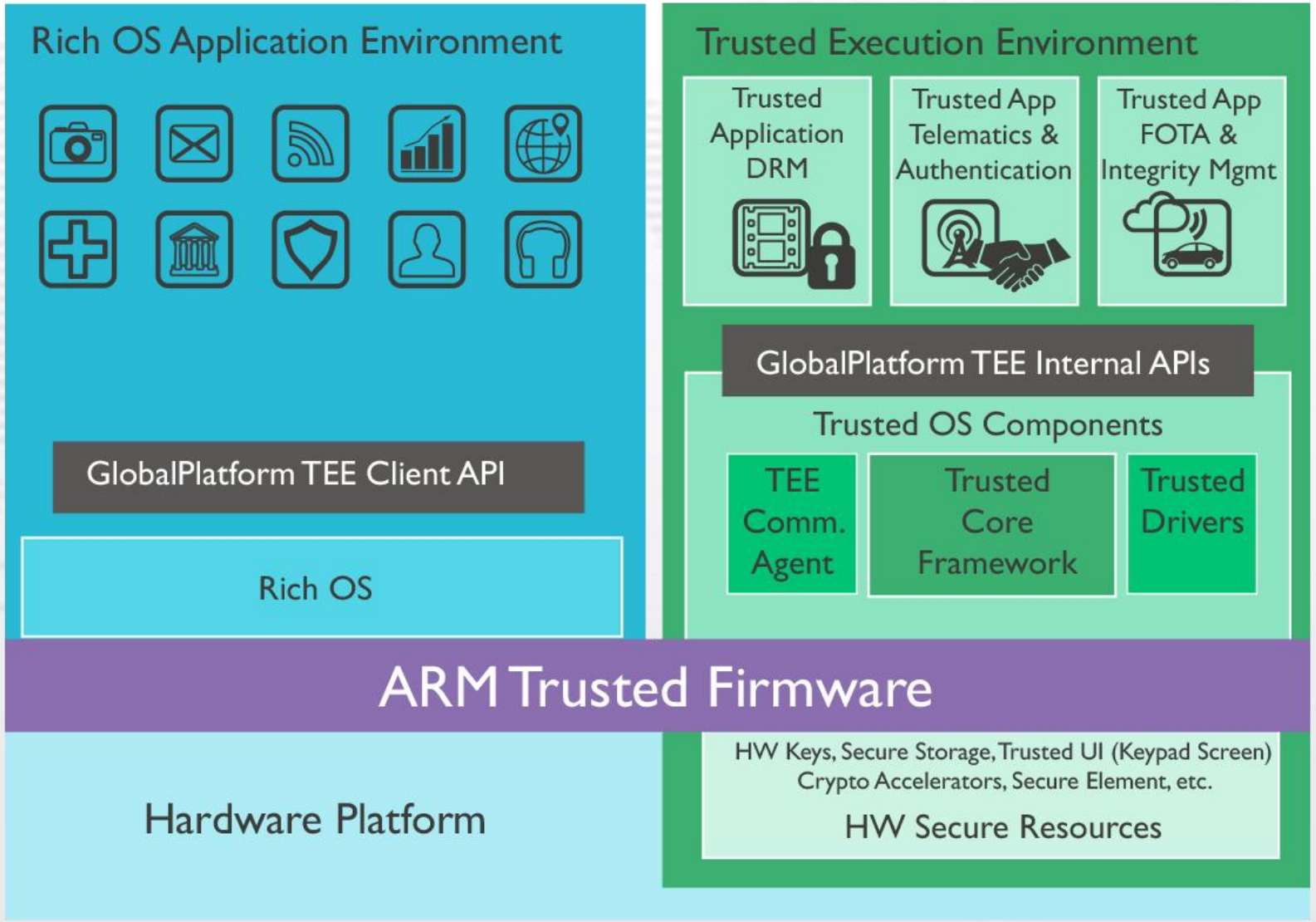
TrustZone在概念上将SoC的硬件和软件资源划分为安全(Secure World)和非安全(Normal World)两个世界，所有需要保密的操作在安全世界执行（如指纹识别、密码处理、数据加解密、安全认证等），其余操作在非安全世界执行（如用户操作系统、各种应用程序等），安全世界和非安全世界通过一个名为Monitor Mode的模式进行转换



安全世界和非安全世界

二、可信计算关键技术

ARM TrustZone技术



ARM官网对TrustZone介绍的应用示意图

三、典型应用案例

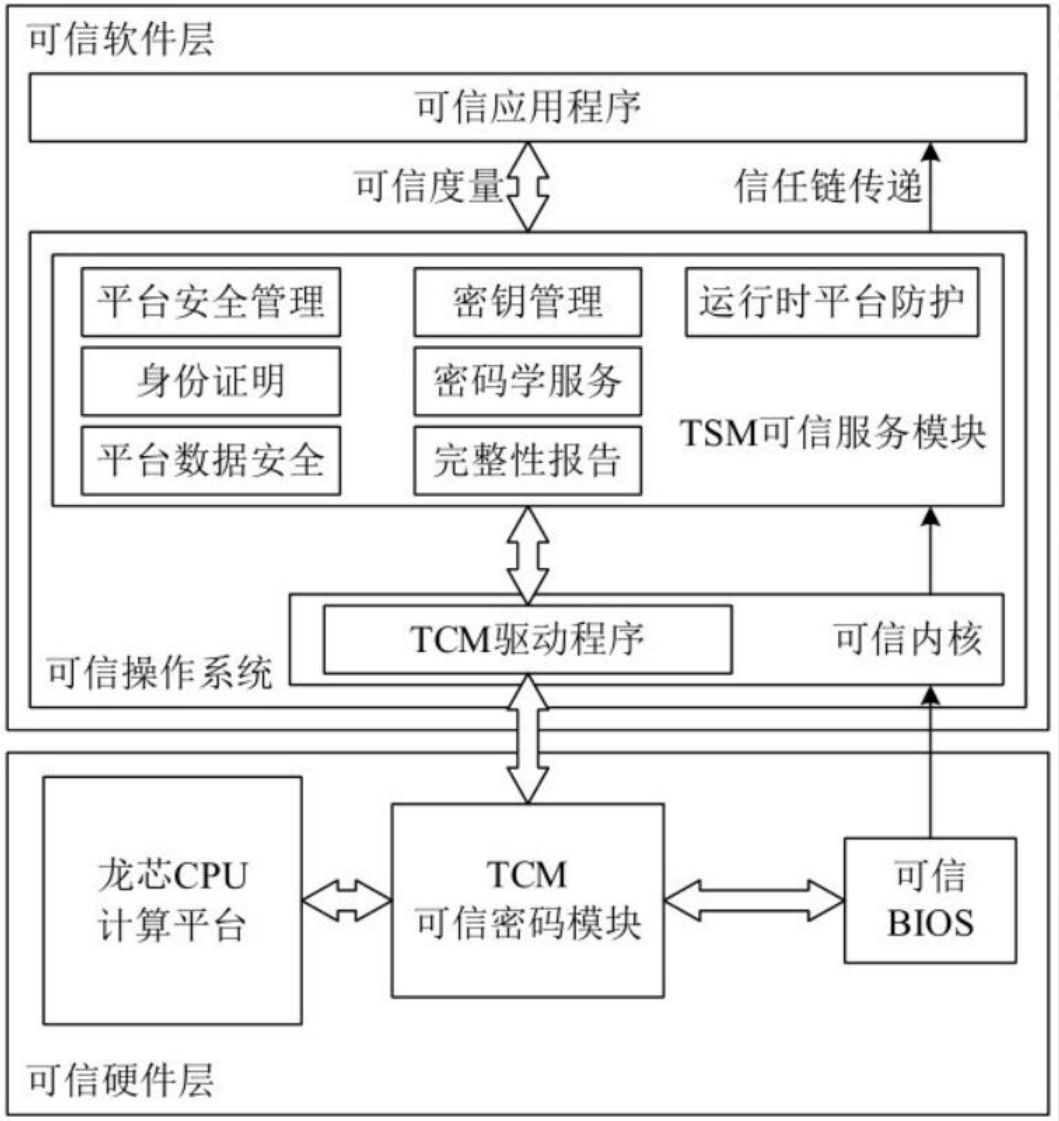
三、典型应用案例

龙芯可信计算体系

可信计算机由可信软硬件系统组成。

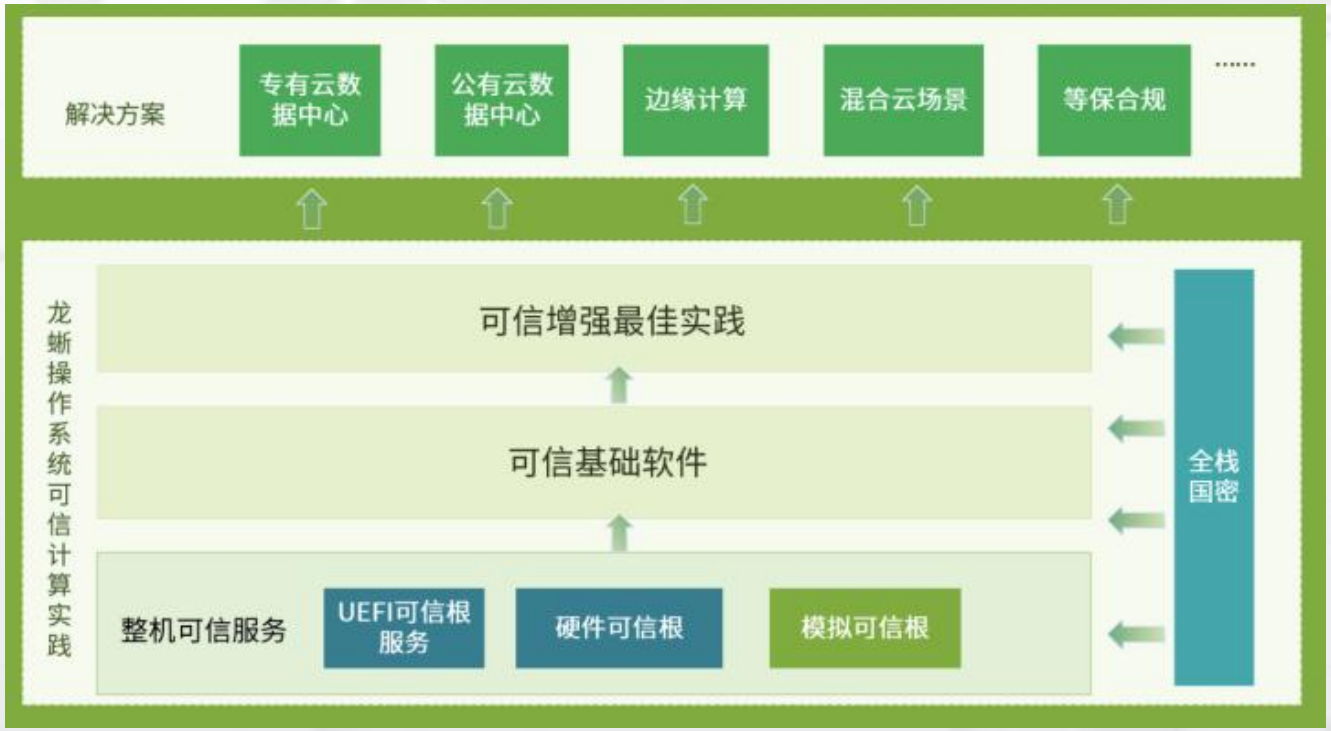
可信硬件层由基本硬件平台设备，包括自主龙芯CPU处理器、存储器、外围输入/输出设备及TCM可信安全芯片等构成。龙芯CPU处理器是整个可信计算平台的基础部件

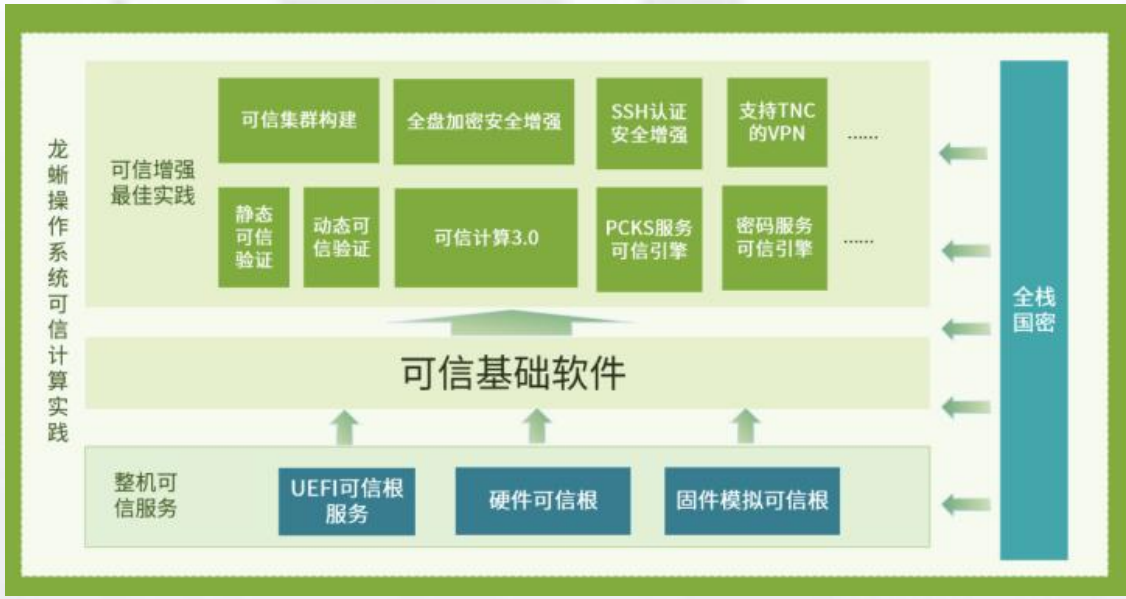
可信操作系统层由基本的操作系统、位于操作系统内核模式的TCM可信安全芯片设备驱动（TDD）和位于用户模式的TSM可信计算软件栈组成



龙芯可信计算体系架构

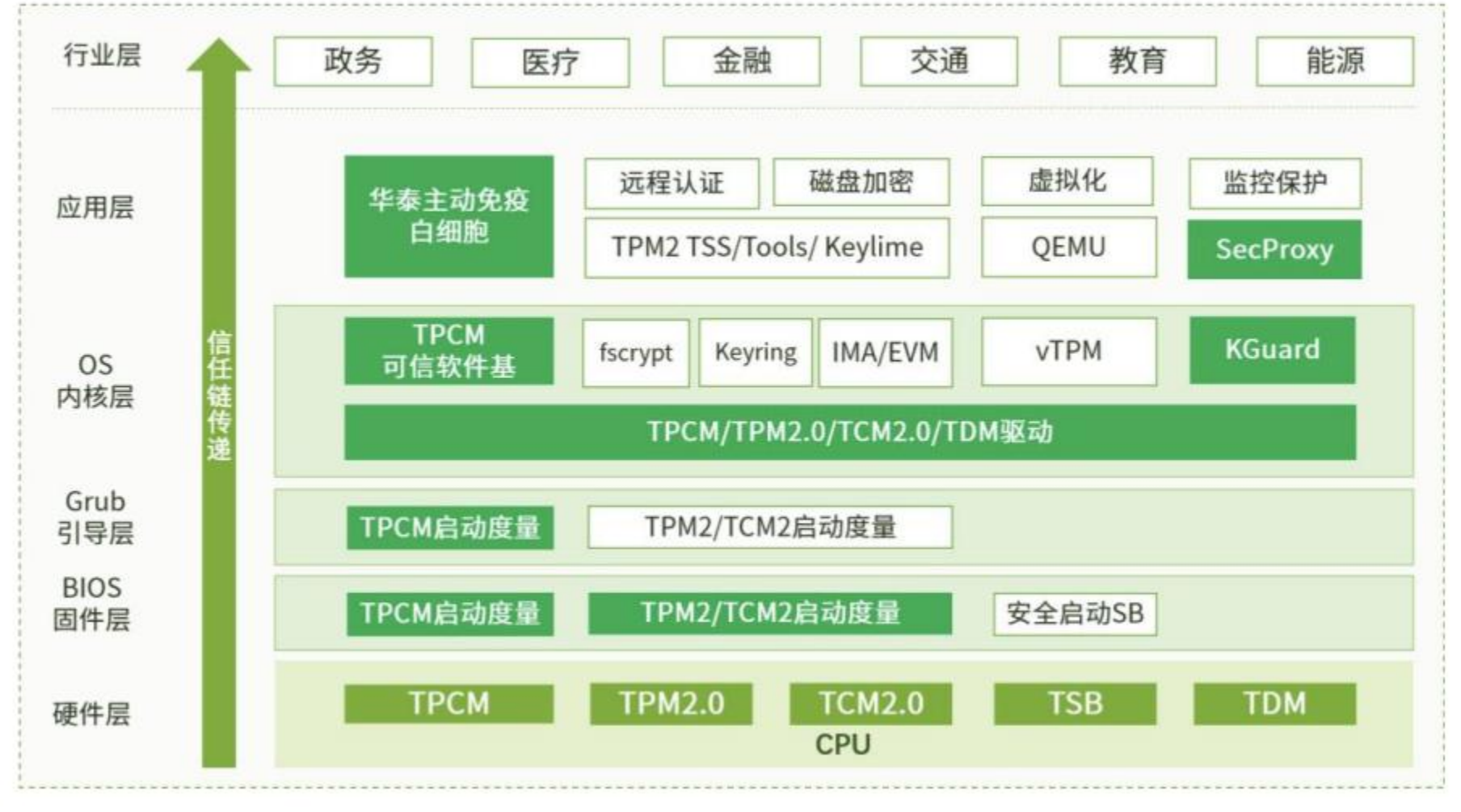
三、典型应用案例





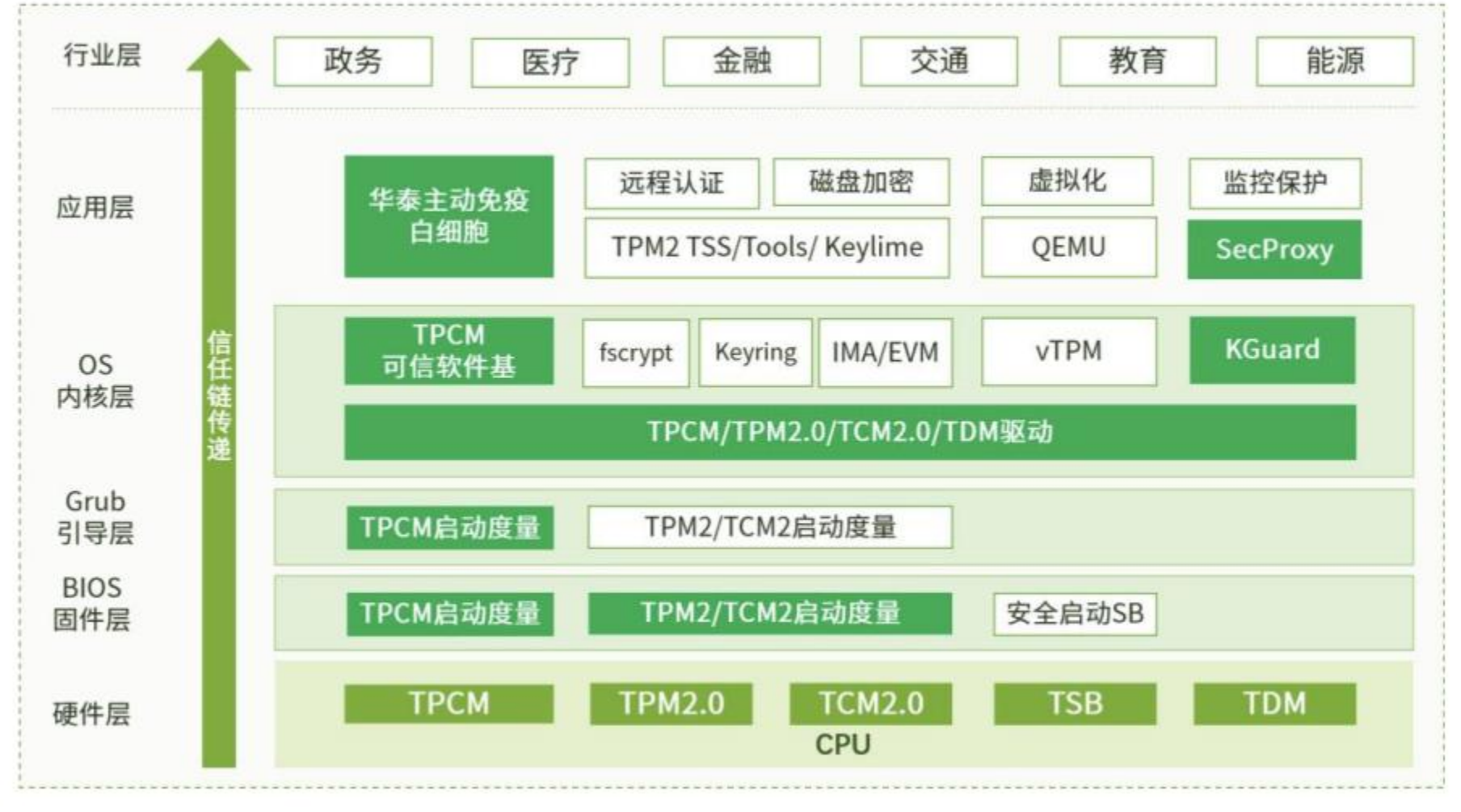
龙蜥可信计算体系

三、典型应用案例



海光平台可信计算体系

三、典型应用案例



海光平台可信计算体系

三、典型应用案例

可信智算互联板卡 TIPU FPGA+SoC双芯片架构

可信智算互联板卡首次提出数算分离计算体系下的异构机密计算机制，突破了计算载荷智能卸载加速、用户态文件加解密系统等计算机制和关键核心技术，实现了不依赖高端CPU特殊指令集的立体化安全防御体系，为敏感数据协同计算提供了新的解决方案，综合安全效能显著提升。



三、典型应用案例

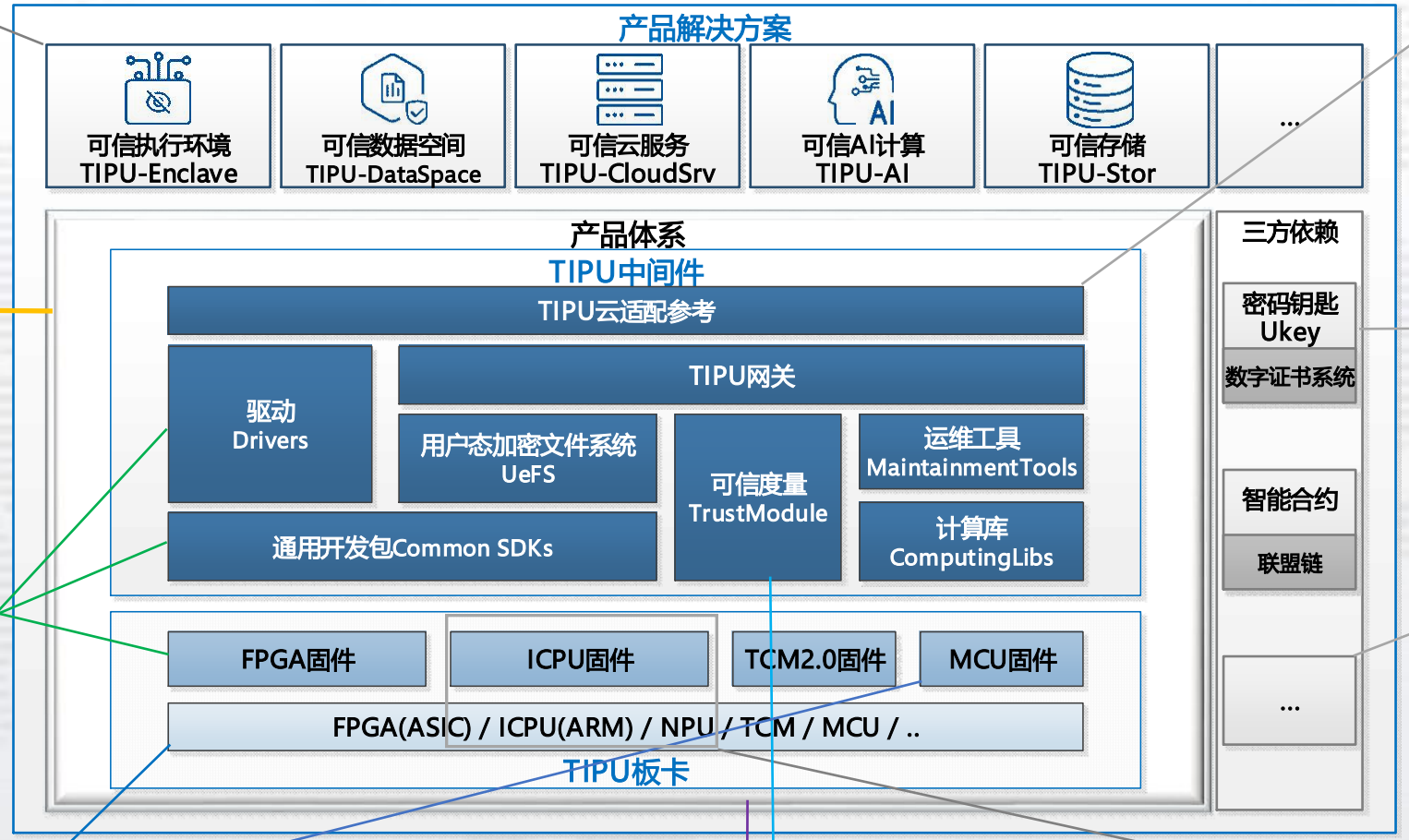
基于开放架构，突破核心技术，形成关键能力

解决方案组：
负责基于TIPU和三方依赖，按行业并结合项目定制需求，研发交付可信平台，过程中沉淀行业级产品解决方案。

云可信组：
整体负责TIPU通用产品，包括板卡和中间件，涉及需求设计、研发测试、罐装和标配交付等，支持解决方案团队。

IPU组：
负责IPU IP模块（网络、存储卸载），包括FPGA固件、驱动及相关通用开发包，另提供硬件设计咨询服务。将继续合作。

硬件组：
负责TIPU单板电路设计仿真、打样，并提供硬件检测服务。同时提供了核心器件相关的对接支持。



科研组：
学生参与了UeFS研发，隐私计算和AI相关的计算库规划设计将由科研团队负责推进，TIPU团队配合。

北工大TC实验室：
首次合作提供TCM元器件（含固件）、TSB以支持内置可信，另授权主机测TSB和业务模块。将继续合作。

梯度云等私有云厂商：
在与这些商业云适配对接时，云厂商支持试用版本地部署，并在我方对接适配过程中提供必要的技术支持。

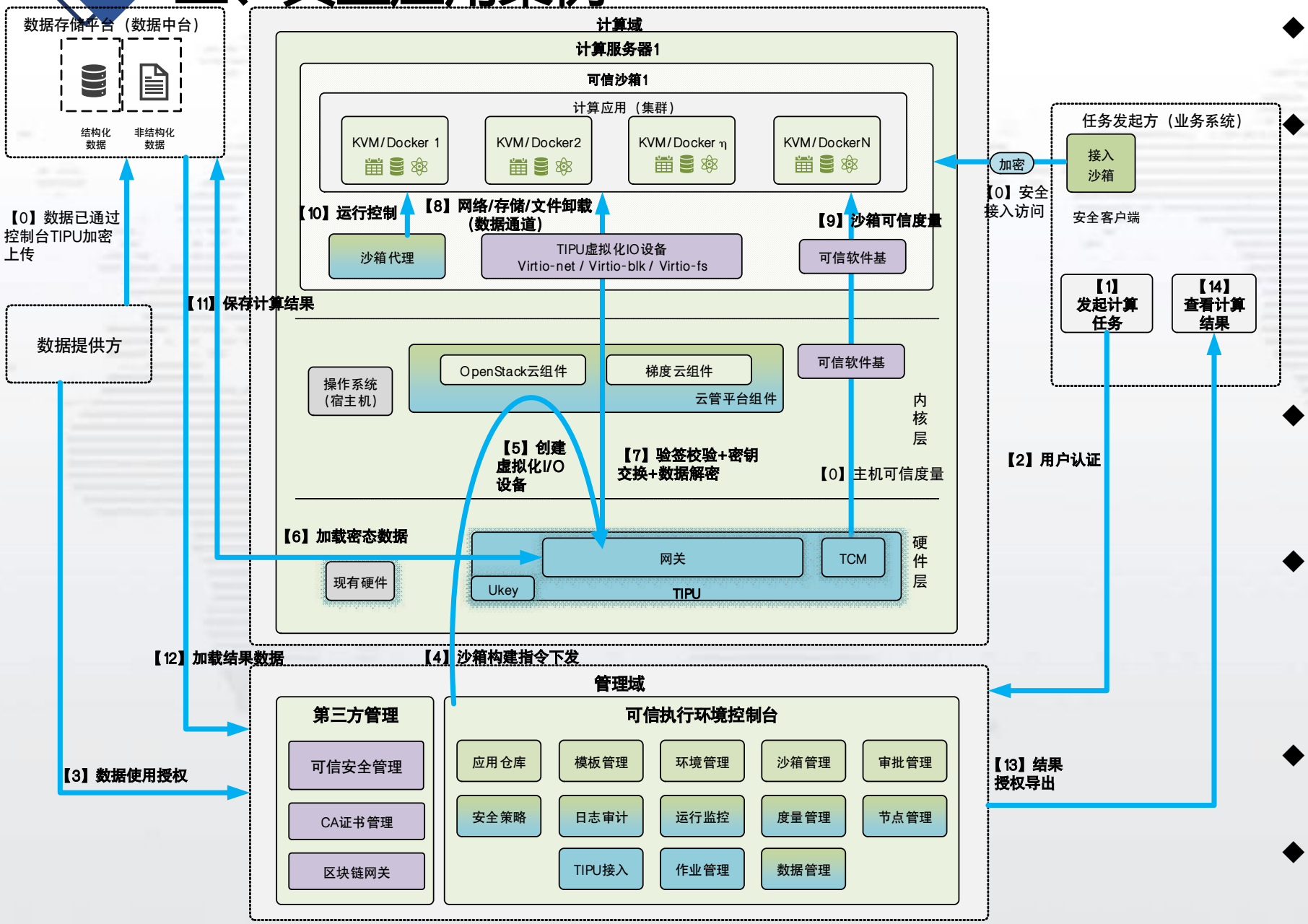
数盾/国泰网信安全厂商：
安全厂商负责提供符合国标的数字证书系统和配套密码钥匙，并在我方集成过程中提供必要的技术支持服务。

深流密码卡厂商：
针对其Venus-01/Pluto-08两种卡进行了试用和测试，后续考虑Pluto-08与TIPU集成，以便申请密评资质。

瑞芯微/飞凌IC厂商：
瑞芯微芯片厂商提供SDK和技术支持服务，飞凌提供集成了瑞芯微芯片的核心板及OS，可提供相关技术支持。

三、典型应用案例

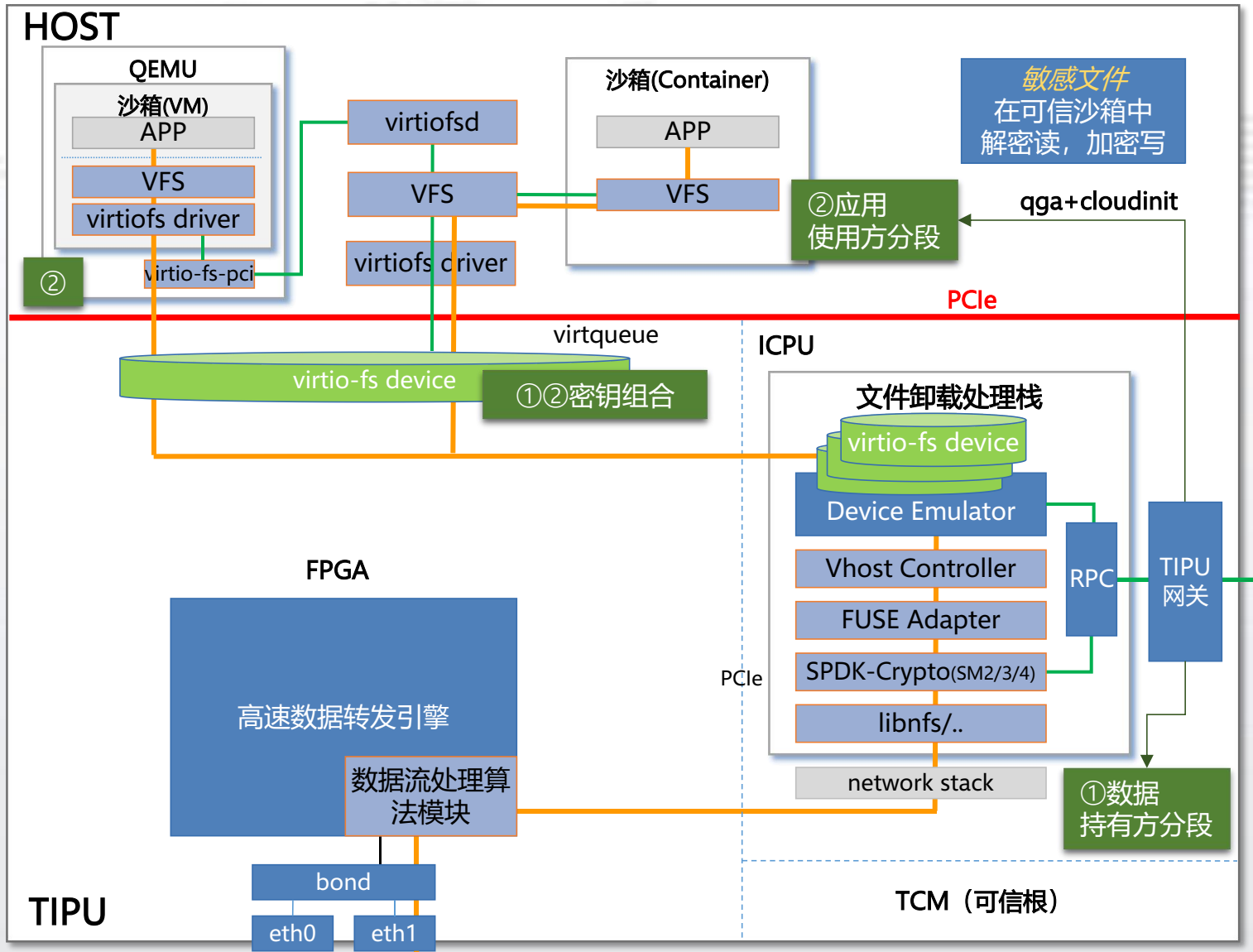
TIPU可信计算流程



- **预准备**——基于UKey实现了端到端安全访问；数据通过可信控制台加密上传
- **发起作业任务**——数据使用方（业务系统）先通过密码和Ukey双因子认证登录，然后发起可信计算作业任务，以工单方式申请数据使用权；数据提供方以同样方式登录后，授权确认后，可下发沙箱构建指令到目标节点
- **TIPU准备数据**——目标节点TIPU先创建虚拟化I/O设备，然后通过后端存储客户端加载远程密态数据文件，完成数据准备；
- **沙箱使用数据**——目标节点上沙箱启动时TIPU上自动完成密钥合并解封，然后解密，并通过虚拟化I/O设备将数据文件直通给沙箱
- **结果受控导出**——沙箱中应用使用数据完成计算后，可选择结果数据授权后导出
- **可信度量**——支持对主机及其上沙箱进行可信度量

三、典型应用案例

用户态加密文件系统UeFS



基于UeFS构建可信沙箱，实现数据保护，其特性：

- 文件直通：存储中的数据文件通过TIPU直通主机沙箱
- 多重加速：转发引擎、SPDK/vDPA等DMA技术、Crypto引擎多维度提升处理性能
- 密钥分发：基于持有者Ukey生成动态密钥，结合TIPU对其加密保护，并分段分发应用使用方，实现授权
- 数据安全：数据存、传、用全链路国密算法加密保护
- 沙箱隔离：基于安全策略和IO审计等技术实现其隔离沙箱，并数据被防窃取
- 内置可信：TCM信任链使TIPU可信，并支持沙箱可信

三、典型应用案例

芯片应用：基于IPU的可信数据空间基础设施解决方案



可信数据空间



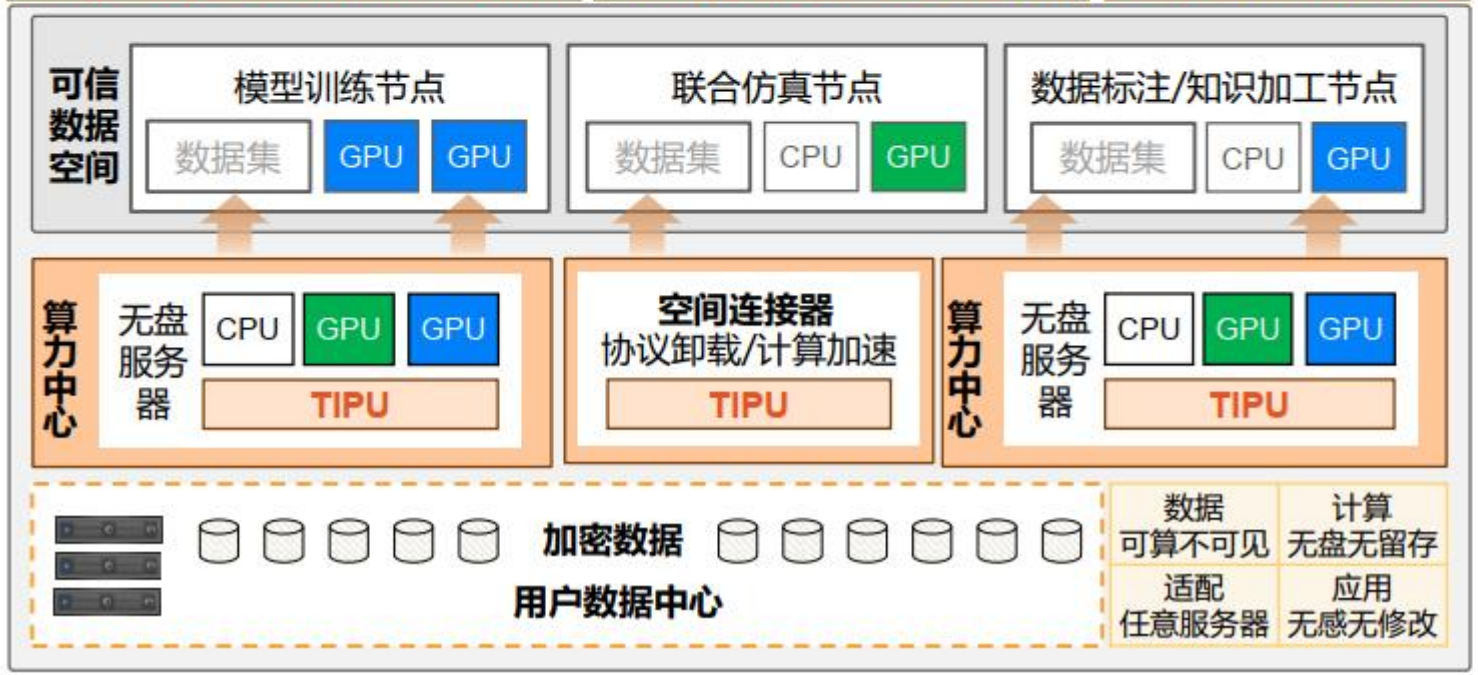
大模型第三方训练推理



多方联合仿真和研发

https://n.sinaimg.cn/sinakd20230605s/64/w1024h640/20230605/2002-a9137b857d010b1a7a6076102533428e.jpg

高速互联，跨节点跨GPU加速 | 数据不出域，可算不可见 | 全程可信可控可证



场景与挑战

场景

- 关基行业的可信计算和数据安全保护基础设施
- 数据要素交易的可信数据空间基础设施

挑战

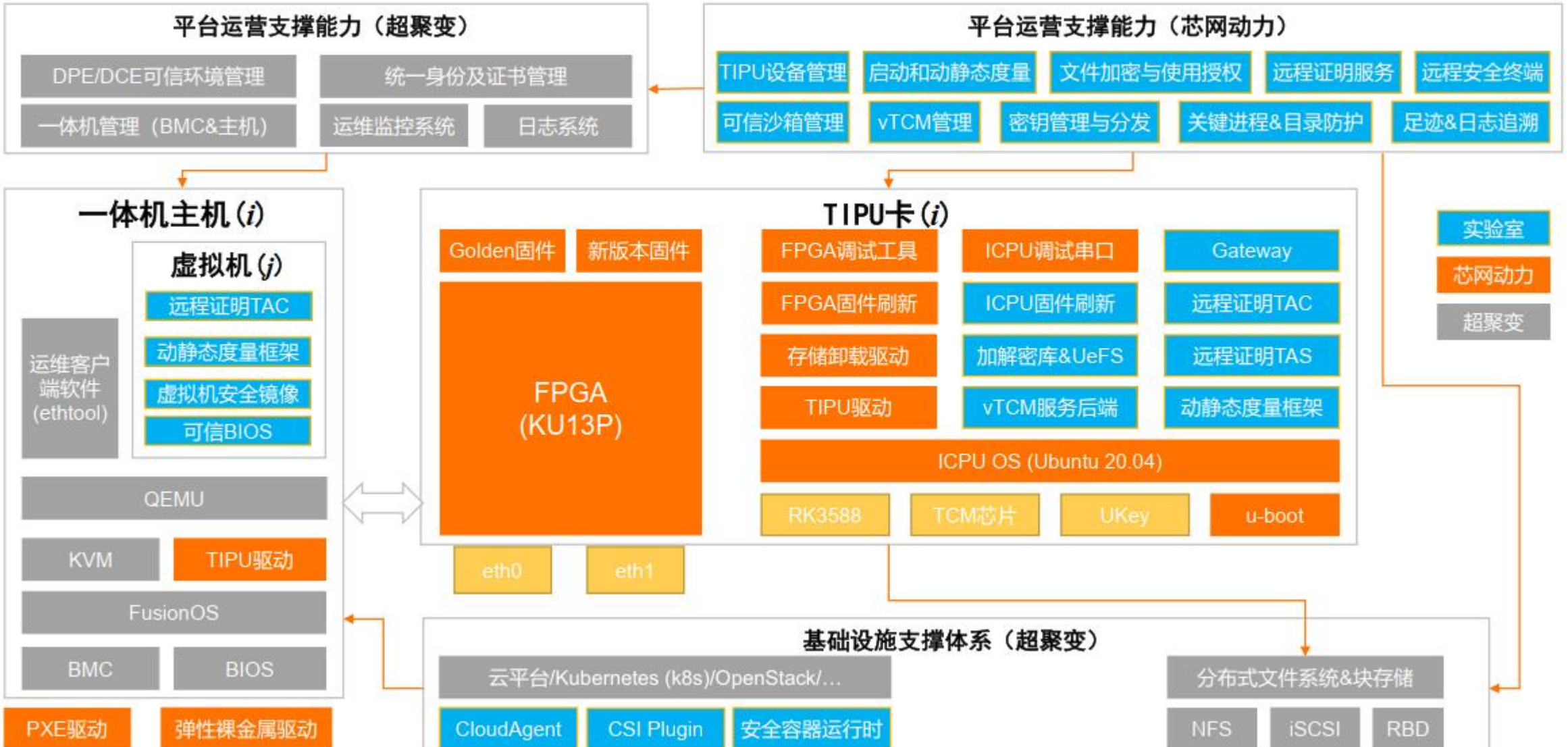
- 传统联邦学习，隐私计算和TEE等技术受限于性能，应用场景约束，特定厂家处理器依赖和模型应用的侵入修改，都未能有效规模应用

基于CCE1.0芯片的TIPU解决方案创新

- 基于**vTCM和远程证明**，实现裸机/虚机/容器**可信计算环境**
- 基于虚拟化卸载实现**计算环境隔离**和**数据保护**
- 业界唯一不依赖处理器架构，无需修改模型和应用软件，接近原生计算性能的数据保护方案

三、典型应用案例

芯片应用：可信数据空间产品基础支撑层功能拓扑图



四、问题思考与研讨

四、问题思考与研讨

思考1：可信计算技术在信息空间（数据空间）中的作用是什么?

思考2：结合业务，计算可信之外，信息自身的价值可信如何保障?

思考3：良好的信息价值，对未来构建高效的信息环路有何帮助?